



Cyber Security Risk Assessment

Qualitative Approach

LEADERS IN INCIDENT RESPONSE

Prepared by:

Gautam Mudaliar

Macy Hoang

Pratik Nesarkar

Shruti Singh

ISTM 635 - Business Information Security



Table of Contents

1. Executive Summary	04
2. Introduction	04
3. Methodology Overview	05
4. Step 1: Identify Key Business Processes and IT Assets	
4.1 Business Processes (BP1–BP3)	06
4.2 IT Asset Inventory (PDIS, ECDS, FRKS, etc.)	07
5. Step 2: Identify Vulnerabilities	09
6. Step 3: Identify Threats	11
6.1 Threat Sources and Events (Adversarial/Accidental)	12
6.2 Threat Relevance Assessment	13
7. Step 4: Estimate Likelihood	
7.1 Motivation of Threat Agent/Source	14
7.2 Ease of Exploitability (CVSS v3.1)	15
7.3 Likelihood of Threat Initiation	16
7.4 Likelihood of Adverse Impact	17
7.5 Overall Likelihood of Threat Events	18
8. Step 5: Estimate Impact on IT Assets and Organization	
8.1 Impact on Confidentiality, Integrity, and Availability	19
8.2 Impact on Business Operations and Legal Exposure	20
8.3 Final Impact Value (FIV) Calculations	21
9. Step 6: Estimate Cybersecurity Risk	

9.1 Risk Matrix and Final Risk Levels	22
9.2 Ranked Risks Across AMC Systems	23
10. Summary of the Assessment Process	24
11. Recommendations and Remediation Priorities	25
12. Conclusion	26
13. References	27
14. Appendices	
A. Adversarial Threat Event Examples (from NIST SP 800-30)	28
B. Vulnerability Details	30
C. Threat Agent Motivation Scoring Tables	32
D. Exploitability Scoring Methodology (CVSS v3.1)	33
E. Impact Scales and Assumptions	34

Cybersecurity Risk Assessment- Qualitative Approach

[Adapted from NIST Guide for Conducting Risk Assessment NIST Special Publication 800-30 Revision 1]

EXECUTIVE SUMMARY

This report presents a comprehensive qualitative cybersecurity risk assessment for Aggieland Medical Center (AMC), developed in alignment with the frameworks outlined in NIST SP 800-30 Revision 1. The primary objective is to identify, assess, and prioritize cybersecurity risks across AMC's core clinical, administrative, and operational systems — and to provide actionable guidance tailored to the healthcare sector's regulatory and service delivery demands.

AMC operates mission-critical systems such as the Patient Data Information Server (PDIS), Emergency Care Data System (ECDS), and Financial Record Keeping Server (FRKS). These systems collectively manage sensitive health data, real-time clinical workflows, and financial operations — and are relied upon to deliver safe, compliant, and uninterrupted patient care.

Through a structured six-step methodology, our risk assessment uncovered several high-risk vulnerabilities and threat events that jeopardize over 10,000 patient records, financial integrity, and operational continuity. These include:

- Use of unsupported legacy systems (e.g., RedHat 6 with known CVEs)
- Excessive user privileges without formal access review
- Weak email and network segmentation exposing internal systems to phishing and lateral movement
- Vendor systems (e.g., MLS) connected without adequate isolation or auditing
- Shared workstations and lack of session timeouts increasing insider misuse potential

From a regulatory standpoint, these issues significantly increase AMC's exposure under the HIPAA Security and Privacy Rules, with non-compliance potentially resulting in fines of up to \$1.5 million per violation. Moreover, reputation damage from a public breach could undermine patient trust, a foundational asset in healthcare delivery.

Threat events were prioritized not simply by frequency, but by their potential impact on patient safety, data confidentiality, business continuity, and legal compliance. For example, while legacy OS vulnerabilities present technical concerns, the insider threat stemming from excessive privileges and unrevoked credentials represents a higher likelihood-risk combination due to observed behavior patterns and lack of monitoring.

To mitigate these risks, we recommend an integrated remediation strategy that includes:

- Role-Based Access Control (RBAC) enforcement and periodic privilege audits
- Phased decommissioning of legacy platforms and unsupported systems
- Vendor segmentation and third-party risk monitoring
- Implementation of multi-factor authentication (MFA) across all externally accessible systems
- Comprehensive security training for clinical and administrative staff tailored to insider threat vectors

Looking forward, AMC can significantly reduce its risk exposure by investing in modern identity governance, automated security monitoring, and resilience planning aligned with HIPAA and HITECH frameworks. These improvements will not only protect information assets but also reinforce AMC's mission of patient care, trust, and operational excellence.

This assessment was conducted by the ISTM 635 Risk Consulting Team using healthcare-specific threat modeling, vulnerability analysis, and qualitative scoring methodologies to ensure that results are both actionable and mission-aligned.

INTRODUCTION

Cybersecurity risk assessment is one of the essential components of Aggieland Medical Center's (AMC) organizational risk management process. As a healthcare provider handling sensitive patient information, financial records, and life-critical systems, AMC must continually identify, estimate, and prioritize risks to its IT assets, operations, personnel, and stakeholders resulting from the use and management of information systems.

The purpose of this assessment is to identify: (i) threats relevant to AMC's operational environment or posed indirectly through vendors and third-party dependencies; (ii) vulnerabilities—technical, administrative, or physical—embedded within AMC's IT infrastructure and business practices; (iii) potential impacts to operations, data integrity, patient safety, and regulatory compliance should threats exploit those vulnerabilities; and (iv) the likelihood of such harmful events occurring. According to NIST Special Publication 800-30 (Revision 1), cybersecurity risk assessments can be conducted at three levels or tiers, i.e., Tier 1 (organization level), Tier 2 (business process level), and Tier 3 (information systems level). Please refer to the document on NIST Special Publication 800-30 (Revision 1) for more details on these three tiers and how they are related to each other. Note that cybersecurity risk assessments are not a one-time activity that provides permanent and definitive information for decision makers to guide and inform responses to information security risks. Rather, organizations employ risk assessments on an ongoing basis across all the tiers in the risk management hierarchy—with the frequency of the risk assessments and the resources applied during the assessments, proportionate to the expressly defined purpose and scope of the assessments.

Qualitative assessment of cybersecurity risk employs a set of methods, principles, or rules for assessing risk based on nonnumerical categories or levels. However, the range of values in qualitative assessments is comparatively small in most cases, making the relative prioritization or comparison within the set of reported risks difficult. Additionally, unless *each value is very clearly defined or is characterized by meaningful examples, different experts relying on their individual experiences could produce significantly different assessment results*. The repeatability and reproducibility of qualitative assessments are increased by an explanation of assessed values (e.g., this value is high because of the following reasons) and using tables or other well-defined functions to combine qualitative values. This document provides a step-by-step process to conduct cybersecurity risk assessment using qualitative approach.

STEP 1: IDENTIFY KEY BUSINESS PROCESSES AND IT ASSETS

In this step, the cybersecurity risk assessment team identified the key business processes implemented at Aggrieland Medical Center (AMC), along with the IT assets deployed to support them. This identification provides the foundation for understanding where disruptions due to cybersecurity incidents could critically affect AMC's ability to deliver services, meet compliance obligations, and maintain patient trust.

STEP 1A: IDENTIFY KEY BUSINESS PROCESSES

Objective: This step is necessary because any disruption in the business processes due to cybersecurity breach can have an operational, financial, and legal impact for the target organization. For example, a cyberattack on Colonial Pipeline in 2021 shut down the oil pipeline resulting in major financial and operational impact on Colonial's business.¹ Therefore, it is important that we assess the cybersecurity risks to these processes. NIST Special Publication 800-30 covers this aspect of risk assessment at the *Tier 2* level.

A business process is defined as a series of tasks, or a set of activities performed by people or systems in a structured manner to attain a pre-defined objective. Business processes can be simple or complex – simple processes often require fewer steps to execute whereas more complex processes not only involve more steps but are more likely to need to be governed by business rules. Any disruption in the efficient and streamlined execution of business processes can have an adverse impact on the success of business operations and growth. Business processes can be broadly classified as follows.

¹ <https://www.cisa.gov/news-events/news/attack-colonial-pipeline-what-weve-learned-what-weve-done-over-past-two-years>

A business process at AMC represents a structured sequence of tasks involving personnel, technology, and policies aimed at achieving clinical, operational, or administrative outcomes.

- **Core Business Process-** A business' core processes are those processes that help an organization perform its primary functions. Without these processes, an organization would cease to meet its operational and strategic objectives. Processes that generate revenues for an organization are a good example of core business processes.
- **Supporting Business Process-** These are the processes that enable core processes to be conducted. Despite not generating any income for the business, they are still important since their disruption can adversely impact the efficiency and effectiveness of one or more core business processes. For example, business processes dealing with human resource management often do not have any direct involvement in generating revenues. However, these processes are responsible for helping to hire people with the skills needed to implement one or more core business processes.
- **Management Process-** These processes involve planning, measuring, monitoring, and controlling the core and support processes. Their purpose is to make sure that the business is running efficiently. They are responsible for ensuring compliance with regulations, addressing any opportunities or threats, and ensuring the continued overall success of the business. An example of a management process for the vehicle manufacturer would be sales forecasting, as this helps to project future revenue to enable the business to run smoothly.

TABLE 1: Business Processes Identified for Cybersecurity Risk Assessment					
Process ID	Process Name	Activities-Tasks	Type of Process		
			Core	Support	Management
BP1	Patient Process	- The patient schedules an appointment (via scheduling staff using PDIS). - Patient check-in occurs at the front desk; initial records are accessed or updated. - Healthcare providers examine the patient and record diagnosis and treatment information into PDIS and/or ECDS. - Lab tests and imaging are ordered and results uploaded to PDIS. - Pharmacy staff dispense medication via RxS and update patient records. - Discharge information and follow-up appointments are documented in the system. - Patient data is maintained securely in PDIS for future encounters.	X		
BP2	Financial Process	- Patient financial data is recorded or updated in the Financial Record Keeping Server (FRKS). - Insurance eligibility is verified, and claims are submitted for processing. - Billing staff prepare invoices based on services recorded in PDIS/ECDS. - Payments are received from insurance providers and/or patients. - Financial discrepancies are identified and resolved by billing staff.	X		

		- Provider credentials and authorizations are verified and logged for claim validity. - Payroll and salary information for staff are maintained in the Personnel Management Server (PMS).			
BP3	Supporting Process	- IT staff and ABC Systems maintain system availability and handle user account setup. - Medical supplies are ordered by staff through the Medical Logistics Server (MLS). - Vendors remotely access MLS to process procurement and delivery. - Email communications are conducted between staff and departments using the internal server. - ABC Systems and AMC IT monitor firewall and server performance to ensure uptime. - Help desk resolves basic technical issues reported by users. - Data backups and system updates are managed periodically by IT and vendors.		X	

STEP 1B: IDENTIFY IT ASSETS

Objective: For AMC, the integrity, availability, and confidentiality of IT assets directly impact critical business operations such as patient care, financial processing, and pharmacy logistics. This step is necessary because a cyberattack on IT assets can disrupt the business processes that rely on these IT assets, which in turn affects an organization's capability to meet its operational and strategic goals and could expose the organization to legal actions. NIST Special Publication 800-30 covers this aspect of risk assessment at the *Tier 3* level.

TABLE 2: IT Assets at AMC (system, component, hardware, and software levels)				
Asset ID	System	Components	HW	SW
IT-A	Patient Data Information Server (PDIS)	- Database Server - Authentication System	- Server hardware - Network switches - Backup storage devices	- Database management software - Operating system (Linux) - User access control software
IT-B	Emergency Care Data System (ECDS)	- Medical Records Database - User Access Portal	- Workstations in emergency rooms - Secure network connections	- Patient record software - Encryption and security software
IT-C	Financial Record Keeping Server (FRKS)	- Billing Database - Insurance Processing System	- Dedicated financial data servers - Workstations for financial team	- Financial record software - Accounting and compliance applications
IT-D	Personnel Management Server (PMS)	- Employee Database - Payroll Management	- HR workstations - Server storage for personnel data	- Payroll processing software - Personnel management application

IT-E	Medical Logistics Server (MLS)	- Procurement Management System - Vendor Access Portal	- Supply chain workstations - Server storage for procurement records	- Inventory management software - database
IT-F	Pharmacy System (RxS)	- Drug Dispensing System - Payment Processing Module	- Automated drug dispensing machines - POS (Point of Sale) devices	- Pharmacy management software - transaction system
IT-G	Email Server	- Internal Email Platform	- Email hosting servers - User workstations	- Sendmail 8.9.3 - security and spam filtering
IT-H	Firewall (Cisco ASA)	- Perimeter Security System	- Cisco ASA firewall appliance	- management software
IT-I	Workstations and Laptops	- User Terminals - Hospital Information System Access	- Desktop computers - Laptops - Network adapters	- Operating systems (Windows/Linux) - software
IT-J	Remote Access Systems	- Secure Physician Access to PDIS	- Remote desktop devices - VPN access points	- VPN software - authentication protocols

TABLE 3: IT Assets Identified for Cybersecurity Risk Assessment

Asset ID	Asset Description	Justification
IT-A	Patient Data Information Server (PDIS)	Stores critical patient records; downtime affects all medical operations
IT-B	Emergency Care Data System (ECDS)	Essential for emergency medical decisions and patient care
IT-C	Financial Record Keeping Server (FRKS)	Stores billing and insurance data; breaches can lead to financial loss and legal issues
IT-D	Personnel Management Server (PMS)	Manages employee records, salaries, and credentials
IT-E	Medical Logistics Server (MLS)	Tracks medical supplies and procurement; vendors access this remotely
IT-F	Pharmacy System (RxS)	Controls automated drug dispensing and payment processing
IT-G	Email Server	Facilitates internal communication and coordination
IT-H	Firewall (Cisco ASA)	Protects network from unauthorized access

IT-I	Workstations and Laptops	Used by physicians, nurses, and staff for daily operations
------	--------------------------	--

Cyber risks cannot be meaningfully assessed without understanding what the organization does — and which systems support those activities. Identifying business processes ensures the risk analysis is aligned with what actually matters to AMC's operations (e.g., patient care, billing, HR), while IT asset identification links risks directly to technology infrastructure.

What we did:

- Mapped three major business process categories: Patient Care (core), Financial Management (core), and HR/Operations (supporting).
- Identified and classified 10 critical IT systems including PDIS, FRKS, ECDS, RxS, and MLS, along with their components and data sensitivity.

STEP 2: IDENTIFY VULNERABILITIES

A *vulnerability* is a weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source or agent. Most information system vulnerabilities can be associated with security controls that either have not been applied (either intentionally or unintentionally), or have been applied, but retain weakness. Vulnerabilities are not identified only within IT assets. Viewing information systems in a broader context, vulnerabilities can be found in-

- Organizational governance structures (e.g., the lack of effective risk management strategies and adequate risk framing, poor intra-agency communications, inconsistent decisions about relative priorities of missions/business functions, or misalignment of enterprise architecture to support mission/business activities).
- External relationships (e.g., dependencies on energy sources, supply chains, information technologies, and telecommunications providers).
- Business processes (e.g., poorly defined processes or processes that are not risk-aware)
- Enterprise/information security architectures (e.g., poor architectural decisions resulting in lack of diversity or resiliency in organizational information systems).
- Specific IT assets such as computers, laptops, mobile devices, servers, network devices, operating systems, applications etc. Information on technical vulnerabilities can be found in the National Vulnerability Database (<https://nvd.nist.gov/>).

At AMC, vulnerabilities represent exploitable weaknesses across systems, procedures, or physical infrastructure that could be leveraged by a threat agent to disrupt operations, compromise sensitive data, or cause reputational harm. These vulnerabilities span beyond IT systems to include organizational governance, partner dependencies, and staff practices.

Vulnerability Classification- For the purposes of this assessment, vulnerabilities have been classified as follows.

- **Technical:** Gaps in technical/logical controls in the organization's systems, e.g., misconfigured routers, backdoors in programs, weak passwords, personal access points, bad code, system configuration faults, etc.
- **Administrative:** Gaps in policies, procedures, or security activities, e.g., missing acceptable use policies, gaps in termination procedures, or the lack of independence in security testing.

- **Physical:** Gaps in physical, geographical, personnel, or utility provisioning controls, e.g., holes in the fence line, location in a flight path, lack of background checks for sensitive positions, and lack of redundant power supply.

NOTE: For technical vulnerabilities that have been assigned a CVE ID, more details on such vulnerabilities are available on <https://nvd.nist.gov> and <https://www.cvedetails.com/>.

TABLE 4: Vulnerabilities Present in the Organization						
IT Asset ID	Vulnerability ID	Vulnerability	Classification			Details
			Technical	Administrative	Physical	
IT-C	V1	Excessive Privileges Accumulation	X	X		Employees inherit all privileges of their predecessors, even when switching roles, leading to unauthorized access to sensitive systems. No role-based access control (RBAC) is enforced.
IT-A						
IT-I	V2	Workstations Left Unattended & Unlocked		X	X	Patients and others could have access. Vulnerability discovered during data collection by senior management.
IT-D	V3	Failure to Regularly Review and Revoke Unnecessary Access		X		Employee accounts remain active after termination or role changes, allowing unauthorized access to sensitive HR and payroll data.
IT-F	V4	Weak Authentication for Drug Dispensing Systems		X		No enforcement of strong password policies for pharmacy access, increasing the risk of unauthorized prescription modifications or fraudulent transactions.
IT-B	V5	Failure to Monitor & Log System Activity		X		No routine log monitoring for unauthorized access or suspicious activity within ECDS, increasing risk of undetected breaches or insider threats.
IT-E	V6	Unrestricted Vendor Access Without Security Audits		X		External vendors access MLS remotely for procurement, but no regular audits ensure compliance with security protocols, increasing risk of third-party compromise.

IT-I	V7	Microsoft Windows Kernel Memory Corruption	X			Vulnerability in Windows 7 allows local privilege escalation, enabling an attacker to execute arbitrary code (CVE-2015-6127).
	V8	Remote Code Execution in Windows 10	X			Remote attackers can exploit this vulnerability to gain unauthorized control over workstations, potentially spreading malware across the network (CVE-2024-38063).
IT-G	V9	Sendmail Remote Buffer Overflow	X			Vulnerability in Sendmail 8.9.3 could allow remote attackers to execute arbitrary code by exploiting buffer overflow issues (CVE-2002-0906).
IT-A	V10	SQL Server Privilege Escalation	X			Unpatched vulnerabilities in MS SQL Server could allow attackers to gain unauthorized admin access to the PDIS database (CVE-2022-29143 and CVE-2021-1636).
IT-C	V11	No physical security in the FRKS workstation area.			X	Anyone can wander into the FRKS room and see confidential information displayed on the workstations. Vulnerability discovered during data collection by senior management.
IT-A	V12	Doctors leave PDIS screens on after they have left treatment rooms.			X	Patients and others could have access. Vulnerability discovered during data collection by senior management.
	V13	Lack of qualified personnel to help maintain PDIS.			X	Difficulty to get and retain qualified personnel. Training is sufficient but could be improved. Vulnerability discovered during data collection by senior management.
	V14	Server room is vulnerable to environmental hazards, such as flooding.			X	External events can lead to a denial of access to PDIS, essentially shutting down the hospital. Vulnerability discovered during data collection by senior management.

IT-D	V15	Shared workstations in cramped spaces.			X	Office space is very tight. Employees often remain logged in all day, allowing unauthorized access to sensitive data. Vulnerability discovered on survey results.
------	-----	--	--	--	---	---

To determine where AMC is most exposed, we assessed technical, administrative, and physical weaknesses that could be exploited by threat actors. Vulnerabilities serve as the “doors left open” in an organization’s systems, people, or policies.

What we did:

- Analyzed system scan data, staff behavior, legacy software, and access control gaps.
- Classified vulnerabilities across three types: technical (e.g., unpatched systems), administrative (e.g., weak password practices), and physical (e.g., unsecured terminals).

Documented 16 vulnerabilities across AMC’s IT assets. High-impact issues included unmonitored admin access, legacy RedHat servers, shared workstations, and lack of user training.

STEP 3: IDENTIFY THREATS

A *threat* is any circumstance or event with the potential to adversely impact organizational operations and assets, individuals, and other organizations through an information system via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service. Any threat has two components – *Threat Agents/Sources* and *Threat Events*. *Threat events* are caused by *threat agents/sources* that can intentionally or accidentally **exploit a vulnerability**.

In general, types of threat agents/sources include: (i) hostile cyber or physical attacks; (ii) human errors of omission or commission; (iii) structural failures of organization-controlled resources (e.g., hardware, software, environmental controls); and (iv) natural and man-made disasters, accidents, and failures beyond the control of the organization. Multiple *threat agents/sources* can initiate or cause the same *threat event*—for example, a web server can be taken off-line by a denial-of-service attack (i.e., *threat event*), intentionally by *threat sources/agents* such as a malicious system administrator, an unintentional administrative error, a hardware fault, or a power failure. Various types of **threat agents/sources** are as following.²

- **Adversarial-** Individuals, groups, organizations, or states that seek to exploit the organization’s dependence on cyber resources (i.e., information in electronic form, information and communications technologies, and the communications and information-handling capabilities provided by those technologies). These can include-
 - An individual, e.g., outsider (e.g., hacker), insider (e.g., staff), trusted insider (e.g., IT staff), privileged insider (e.g., top management)
 - A group, e.g., formed on an ad hoc basis, or established (e.g., Anonymous)
 - An organization, e.g., competitor, supplier, trading partner, customer
 - A nation-state

² Source: NIST Special Publication 800-30.

- **Non-adversarial-** These can include-
 - ACCIDENTAL- Erroneous actions taken by individuals while executing their everyday responsibilities.
 - STRUCTURAL- Failures of equipment (e.g., hard drive, processor, router, displays, sensors, fire alarm, sprinkler system etc.), environmental controls (e.g., temperature/humidity controls, power supply), or software (e.g., operating systems, applications) due to aging, resource depletion, or other circumstances which exceed expected operating parameters.
 - ENVIRONMENTAL- Natural or man-made disasters and failures of critical infrastructures on which the organization depends, but which are outside the control of the organization.

Threats exploit identified vulnerabilities and may originate from internal or external actors, either intentionally or accidentally.

For this risk assessment, AMC's threat focus is limited to:

- Adversarial sources (e.g., insiders, hackers, rogue vendors)
- Accidental non-adversarial sources (e.g., staff negligence)

Other non-adversarial sources (e.g., structural failure, environmental disasters) are excluded per scope.

TABLE 5: Assessment Scale to Measure the Relevance of Threat Events ³	
Value	Description
Confirmed	The threat event or TTP has been seen by the AMC.
Expected	The threat event or TTP has been seen by the AMC's peers or partners, including ABC systems and pre-certified vendors for MLS.
Anticipated	The threat event or TTP has been reported by a trusted source, including IT staff and ABC Systems.
Predicted	The threat event or TTP has been predicted by a trusted source, including IT staff and ABC Systems.
Possible	The threat event or TTP has been described by a credible source, including senior management, general staff, physicians, and operational area managers.
N/A	The threat event or TTP is not currently applicable. For example, a threat event or TTP could assume specific technologies, architectures, or processes that are not present in the organization, mission/business process, or information system; or predisposing conditions that are not present (e.g., location in a flood plain). Alternately, if the organization is using detailed or specific threat information, a threat event or TTP could be deemed inapplicable because information indicates that no adversary is expected to initiate the threat event or use the TTP.
TTP => Tactics, Techniques, and Procedures	

³ Source: NIST Special Publication 800-30

TABLE 6: Threats to IT Assets					
Asset ID	Vulnerability ID	Threat ID	Threat Event	Threat Agent/Source	Threat Relevance
IT-C	V1	T1	Unauthorized access to FRKS workstations and confidential information exposure	Unauthorized personnel, visitors, or malicious actors	Possible
IT-A		T2	Unauthorized access due to excessive privileges accumulation	Malicious insiders, former employees with active accounts	Confirmed
IT-D	V2	T3	Unauthorized access or data compromise due to shared workstations in cramped spaces	Employees, unauthorized personnel, or social engineers	Confirmed
IT-I		T4	Unauthorized viewing of patient data due to unattended workstations	Patients, unauthorized personnel, malicious insiders	Possible
IT-D	V3	T5	Unauthorized access to HR and payroll data due to failure to revoke accounts	Former employees, disgruntled insiders, cybercriminals	Expected
IT-F	V4	T6	Fraudulent prescription modifications due to weak authentication	Rogue employees, cybercriminals using compromised credentials	Anticipated
IT-B	V5	T7	Insider threats exploiting lack of system activity monitoring	Disgruntled employees, unauthorized third parties	Expected
IT-E	V6	T8	Supply chain disruption due to lack of vendor security audits	Compromised vendor accounts, third-party hackers	Anticipated
IT-I	V7	T9	Privilege escalation leading to unauthorized system access	Malicious insiders, hackers, malware	Confirmed
	V8	T10	Remote code execution allowing attackers to control workstations	Hackers, malware, advanced persistent threats (APTs)	Anticipated
IT-G	V9	T11	Buffer overflow exploit leading to unauthorized email access or server takeover	Hackers, phishing campaigns, botnets	Anticipated
IT-A	V10	T12	Privilege escalation granting unauthorized admin access to patient data	Malicious insiders, cybercriminals, nation-state actors	Predicted

		T13	SQL injection or unauthorized queries exposing patient data	Hackers, rogue employees, external cybercriminals	Anticipated
IT-C	V11	T14	Unauthorized access to FRKS workstations and confidential information exposure	Unauthorized personnel, visitors, or malicious actors	Possible
IT-A	V12	T15	Unauthorized viewing of patient data	Other patients, unauthorized personnel, or malicious attackers	Possible
IT-D	V15	T16	Unauthorized access or data compromise due to shared workstations in cramped spaces	Employees, unauthorized personnel, or social engineers	Confirmed

A vulnerability is only dangerous if there's a plausible threat actor who can exploit it. This step links vulnerabilities to realistic threat events, including adversarial (e.g., hackers, insiders) and accidental (e.g., staff negligence) sources.

What we did:

- Mapped specific threats (e.g., unauthorized access, SQL injection, prescription fraud) to vulnerabilities.
- Assessed the relevance of each threat using a scale from “Confirmed” to “Possible,” based on AMC’s environment, peer hospitals, and threat intelligence.

We created a threat matrix identifying the most relevant and credible attack scenarios AMC is exposed to — including insider threats, vendor compromises, and privilege escalation.

STEP 4: ESTIMATE THREAT LIKELIHOOD

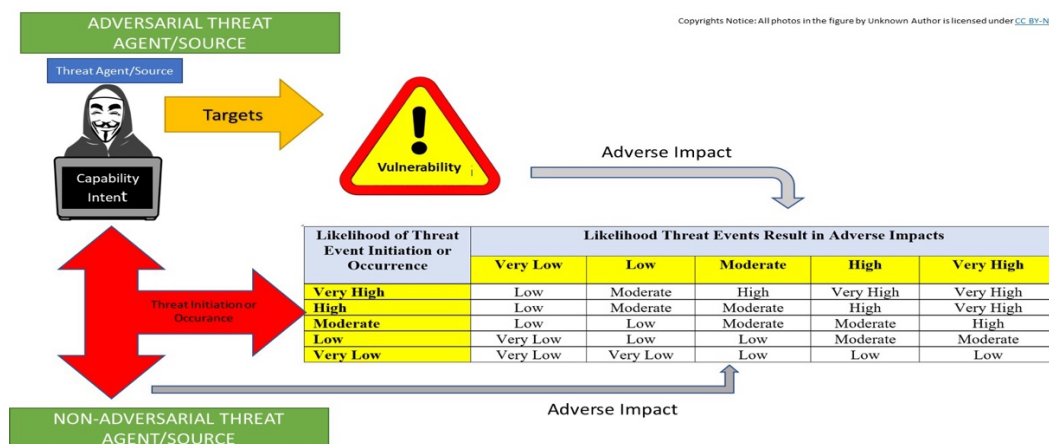


Figure: Overall Likelihood of a Threat Event

STEP 4A: ADVERSARIAL THREATS- The *likelihood of occurrence* is a weighted risk factor based on an analysis of the *likelihood that the threat will be initiated by the threat agent/source*, **AND** *the likelihood that the exploitation (i.e., threat event) will result in an adverse impact* on the organization's IT assets and business processes (See the above figure). In short, the following three components are used to assess the likelihood of a threat happening-

- **Motivation of the Threat Agent/Source to Initiate the Threat Event-** How likely is the threat agent/source to initiate the threat event? We estimate this using the attributes of the **adversarial threat agent/source**: (i) adversary *capability*; (ii) adversary *intent*; and (iii) adversary *targeting*. For **non-adversarial threat events**, the *likelihood of occurrence is estimated using historical evidence, empirical data, or other factors*.⁴ Document the *Adversarial Threat Agent/Source* in the following manner-

For Aggieland Medical Center (AMC), adversarial threats may come from both internal and external actors. These include malicious insiders, cybercriminals, and nation-state threat actors seeking to exploit technical vulnerabilities, misconfigurations, or poor access control. To assess likelihood, we first estimate the motivation of the threat agent/source using attributes defined in NIST SP 800-30 and contextualized for AMC.

TABLE 7A: Assessment of Threat Agent/Source's Motivation						
Threat ID	Threat Agent/Source Description	Source of Information	Capability *	Intent*	Targeting *	Motivation Score**
T1	Unauthorized personnel, visitors, or malicious actors	Senior management reports and data collection	Low	Low	High	Low
T2	Employees, unauthorized personnel, or social engineers	Survey results and operational observations	Moderate	Low	High	Moderate
T3	Malicious insiders, former employees with active accounts	Survey results & access control logs	High	Moderate	High	High
T4	Patients, unauthorized personnel, malicious insiders	Security assessment (Unattended workstations, Pg. 12)	Low	Very Low	Moderate	Low
T5	Former employees, disgruntled insiders, cybercriminals	HR reports & access logs	High	High	High	High
T6	Rogue employees, cybercriminals using compromised credentials	Audit logs & security assessments	Moderate	Moderate	High	Moderate

⁴ Please refer to APPENDIX C for example of assessment scale for threat agent/source.

T7	Disgruntled employees, unauthorized third parties	Security assessment (Lack of logging, Pg. 22)	Moderate	Moderate	High	Moderate
T8	Compromised vendor accounts, third-party hackers	Vendor access logs & security policy review	Moderate	Moderate	High	Moderate
T9	Malicious insiders, hackers, malware	Technical vulnerability data (Windows 7 privilege escalation)	Moderate	High	High	High
T10	Hackers, malware, APTs	Technical vulnerability data (Windows 10 remote code execution)	High	High	High	High
T11	Hackers, phishing campaigns, botnets	Technical vulnerability data (Email server buffer overflow)	Moderate	High	Moderate	Moderate
T12	Malicious insiders, cybercriminals, nation-state actors	Technical vulnerability data (SQL Server privilege escalation)	High	High	High	High
T13	Hackers, rogue employees, external cybercriminals	Technical vulnerability data (SQL Injection)	High	Moderate	High	Moderate
T14	Unauthorized personnel, visitors, or malicious actors	Senior management reports and data collection	Low	Low	High	Low
T15	Other patients, unauthorized personnel, or malicious attackers	Senior management reports and data collection	Low	Very Low	Low	Low
T16	Employees, unauthorized personnel, or social engineers	Survey results and operational observations	Moderate	Low	High	Moderate

TABLE 7B: Look-Up table to estimate the qualitative value of Threat Agent/Source's Motivation				
Capability	Intent	Targeting	Motivation Score	Motivation Score Explanation
Very High	Very High	Very High	Very High	Adversary is almost certain to initiate the threat event
Very High	Very High	High	Very High	Adversary is almost certain to initiate the threat event
Very High	Very High	Moderate	High	Adversary is highly likely to initiate the threat event
Very High	Very High	Low	Moderate	Adversary is likely to initiate the treat event
Very High	Very High	Very Low	Moderate	Adversary is likely to initiate the treat event
Very High	High	Very High	Very High	Adversary is almost certain to initiate the threat event
Very High	High	High	Very High	Adversary is almost certain to initiate the threat event
Very High	High	Moderate	High	Adversary is highly likely to initiate the threat event
Very High	High	Low	Moderate	Adversary is likely to initiate the treat event
Very High	High	Very Low	Moderate	Adversary is likely to initiate the treat event
Very High	Moderate	Very High	High	Adversary is highly likely to initiate the threat event
Very High	Moderate	High	High	Adversary is highly likely to initiate the threat event
Very High	Moderate	Moderate	Moderate	Adversary is likely to initiate the treat event
Very High	Moderate	Low	Moderate	Adversary is likely to initiate the treat event
Very High	Moderate	Very Low	Moderate	Adversary is likely to initiate the treat event
Very High	Low	Very High	Moderate	Adversary is likely to initiate the treat event
Very High	Low	High	Moderate	Adversary is likely to initiate the treat event
Very High	Low	Moderate	Moderate	Adversary is likely to initiate the treat event
Very High	Low	Low	Low	Adversary is unlikely to initiate the threat event
Very High	Low	Very Low	Low	Adversary is unlikely to initiate the threat event
Very High	Very Low	Very High	Moderate	Adversary is likely to initiate the treat event
Very High	Very Low	High	Moderate	Adversary is likely to initiate the treat event
Very High	Very Low	Moderate	Low	Adversary is unlikely to initiate the threat event
Very High	Very Low	Low	Low	Adversary is unlikely to initiate the threat event
Very High	Very Low	Very Low	Low	Adversary is unlikely to initiate the threat event
High	Very High	Very High	Very High	Adversary is almost certain to initiate the threat event
High	Very High	High	Very High	Adversary is almost certain to initiate the threat event
High	Very High	Moderate	High	Adversary is highly likely to initiate the threat event
High	Very High	Low	Moderate	Adversary is likely to initiate the treat event

High	Very High	Very Low	Moderate	Adversary is likely to initiate the treat event
High	High	Very High	High	Adversary is highly likely to initiate the threat event
High	High	High	High	Adversary is highly likely to initiate the threat event
High	High	Moderate	High	Adversary is highly likely to initiate the threat event
High	High	Low	Moderate	Adversary is likely to initiate the treat event
High	High	Very Low	Moderate	Adversary is likely to initiate the treat event
High	Moderate	Very High	High	Adversary is highly likely to initiate the threat event
High	Moderate	High	High	Adversary is highly likely to initiate the threat event
High	Moderate	Moderate	Moderate	Adversary is likely to initiate the treat event
High	Moderate	Low	Moderate	Adversary is likely to initiate the treat event
High	Moderate	Very Low	Moderate	Adversary is likely to initiate the treat event
High	Low	Very High	Moderate	Adversary is likely to initiate the treat event
High	Low	High	Moderate	Adversary is likely to initiate the treat event
High	Low	Moderate	Moderate	Adversary is likely to initiate the treat event
High	Low	Low	Low	Adversary is unlikely to initiate the threat event
High	Low	Very Low	Low	Adversary is unlikely to initiate the threat event
High	Very Low	Very High	Low	Adversary is unlikely to initiate the threat event
High	Very Low	High	Moderate	Adversary is likely to initiate the treat event
High	Very Low	Moderate	Moderate	Adversary is likely to initiate the treat event
High	Very Low	Low	Low	Adversary is unlikely to initiate the threat event
High	Very Low	Very Low	Low	Adversary is unlikely to initiate the threat event
Moderate	Very High	Very High	Very High	Adversary is almost certain to initiate the threat event
Moderate	Very High	High	High	Adversary is highly likely to initiate the threat event
Moderate	Very High	Moderate	Moderate	Adversary is likely to initiate the treat event
Moderate	Very High	Low	Moderate	Adversary is likely to initiate the treat event
Moderate	Very High	Very Low	Moderate	Adversary is likely to initiate the treat event
Moderate	High	Very High	High	Adversary is highly likely to initiate the threat event
Moderate	High	High	High	Adversary is highly likely to initiate the threat event
Moderate	High	Moderate	Moderate	Adversary is likely to initiate the treat event
Moderate	High	Low	Moderate	Adversary is likely to initiate the treat event
Moderate	High	Very Low	Moderate	Adversary is likely to initiate the treat event
Moderate	Moderate	Very High	High	Adversary is highly likely to initiate the threat event

Moderate	Moderate	High	Moderate	Adversary is likely to initiate the treat event
Moderate	Moderate	Moderate	Moderate	Adversary is likely to initiate the treat event
Moderate	Moderate	Low	Moderate	Adversary is likely to initiate the treat event
Moderate	Moderate	Very Low	Moderate	Adversary is likely to initiate the treat event
Moderate	Low	Very High	Moderate	Adversary is likely to initiate the treat event
Moderate	Low	High	Moderate	Adversary is likely to initiate the treat event
Moderate	Low	Moderate	Moderate	Adversary is likely to initiate the treat event
Moderate	Low	Low	Low	Adversary is unlikely to initiate the threat event
Moderate	Low	Very Low	Low	Adversary is unlikely to initiate the threat event
Moderate	Very Low	Very High	Moderate	Adversary is likely to initiate the treat event
Moderate	Very Low	High	Moderate	Adversary is likely to initiate the treat event
Moderate	Very Low	Moderate	Moderate	Adversary is likely to initiate the treat event
Moderate	Very Low	Low	Low	Adversary is unlikely to initiate the threat event
Moderate	Very Low	Very Low	Low	Adversary is unlikely to initiate the threat event
Low	Very High	Very High	Moderate	Adversary is likely to initiate the treat event
Low	Very High	High	Moderate	Adversary is likely to initiate the treat event
Low	Very High	Moderate	Moderate	Adversary is likely to initiate the treat event
Low	Very High	Low	Low	Adversary is unlikely to initiate the threat event
Low	Very High	Very Low	Low	Adversary is unlikely to initiate the threat event
Low	High	Very High	Moderate	Adversary is likely to initiate the treat event
Low	High	High	Moderate	Adversary is likely to initiate the treat event
Low	High	Moderate	Moderate	Adversary is likely to initiate the treat event
Low	High	Low	Low	Adversary is unlikely to initiate the threat event
Low	High	Very Low	Low	Adversary is unlikely to initiate the threat event
Low	Moderate	Very High	Moderate	Adversary is likely to initiate the treat event
Low	Moderate	High	Moderate	Adversary is likely to initiate the treat event
Low	Moderate	Moderate	Moderate	Adversary is likely to initiate the treat event
Low	Moderate	Low	Low	Adversary is unlikely to initiate the threat event
Low	Moderate	Very Low	Low	Adversary is unlikely to initiate the threat event
Low	Low	Very High	Low	Adversary is unlikely to initiate the threat event
Low	Low	High	Low	Adversary is unlikely to initiate the threat event
Low	Low	Moderate	Low	Adversary is unlikely to initiate the threat event

Low	Low	Low	Low	Adversary is unlikely to initiate the threat event
Low	Low	Very Low	Very Low	Adversary is highly unlikely to initiate the threat event
Low	Very Low	Very High	Very Low	Adversary is highly unlikely to initiate the threat event
Low	Very Low	High	Very Low	Adversary is highly unlikely to initiate the threat event
Low	Very Low	Moderate	Very Low	Adversary is highly unlikely to initiate the threat event
Low	Very Low	Low	Very Low	Adversary is highly unlikely to initiate the threat event
Low	Very Low	Very Low	Very Low	Adversary is highly unlikely to initiate the threat event
Very Low	Very High	Very High	Moderate	Adversary is likely to initiate the treat event
Very Low	Very High	High	Moderate	Adversary is likely to initiate the treat event
Very Low	Very High	Moderate	Moderate	Adversary is likely to initiate the treat event
Very Low	Very High	Low	Moderate	Adversary is likely to initiate the treat event
Very Low	Very High	Very Low	Moderate	Adversary is likely to initiate the treat event
Very Low	High	Very High	Moderate	Adversary is likely to initiate the treat event
Very Low	High	High	Moderate	Adversary is likely to initiate the treat event
Very Low	High	Moderate	Moderate	Adversary is likely to initiate the treat event
Very Low	High	Low	Moderate	Adversary is likely to initiate the treat event
Very Low	High	Very Low	Moderate	Adversary is likely to initiate the treat event
Very Low	Moderate	Very High	Moderate	Adversary is likely to initiate the treat event
Very Low	Moderate	High	Low	Adversary is unlikely to initiate the threat event
Very Low	Moderate	Moderate	Low	Adversary is unlikely to initiate the threat event
Very Low	Moderate	Low	Low	Adversary is unlikely to initiate the threat event
Very Low	Moderate	Very Low	Low	Adversary is unlikely to initiate the threat event
Very Low	Low	Very High	Low	Adversary is unlikely to initiate the threat event
Very Low	Low	High	Low	Adversary is unlikely to initiate the threat event
Very Low	Low	Moderate	Low	Adversary is unlikely to initiate the threat event
Very Low	Low	Low	Low	Adversary is unlikely to initiate the threat event
Very Low	Low	Very Low	Very Low	Adversary is highly unlikely to initiate the threat event
Very Low	Very Low	Very High	Moderate	Adversary is likely to initiate the treat event
Very Low	Very Low	High	Low	Adversary is unlikely to initiate the threat event
Very Low	Very Low	Moderate	Very Low	Adversary is highly unlikely to initiate the threat event
Very Low	Very Low	Low	Very Low	Adversary is highly unlikely to initiate the threat event
Very Low	Very Low	Very Low	Very Low	Adversary is highly unlikely to initiate the threat event

- **Ease of Exploitability:** Here we assess the ease with which a vulnerability can be exploited. Exploitability of a vulnerability is a function of *attack vector*, *attack complexity*, *privileges* required by the threat agent/source to exploit the vulnerability, *user interaction*, and the *scope* of the attack.⁵ AMC uses the CVSS v3.1 Exploitability Sub-Score, which factors in attack vector, complexity, required privileges, user interaction, and scope. Each score is calculated per vulnerability and mapped to a qualitative scale to support decision-making.

TABLE 8: Ease of Exploitability Assessment

Vulnerability ID	Attack Vector (AV)	Attack Complexity (AC)	Privilege Required (P)	User Interaction (UI)	Scope (S)	Exploitability Score (CVSS 3.1)
V1	Local	Low	High	None	Changed	High [2.0]
V2	Physical	Low	None	None	Unchanged	Low [0.9]
V3	Network	Low	Low	None	Unchanged	High [2.8]
V4	Local	Low	None	Required	Unchanged	Moderate [1.8]
V5	Local	Low	None	None	Unchanged	High [2.5]
V6	Network	Low	None	None	Unchanged	Very High [3.9]
V7	Local	Low	Low	None	Changed	High [2.0]
V8	Network	High	None	None	Changed	High [2.2]
V9	Network	High	None	None	Changed	High [2.2]
V10	Network	High	None	None	Unchanged	High [2.2]
V11	Physical	Low	None	None	Unchanged	Low [0.9]
V12	Physical	Low	None	None	Unchanged	Low [0.9]
V15	Physical	Low	None	None	Unchanged	Low [0.9]

Notes:

- Details of Vulnerability ID are provided in Table 4.
- Exploitability Score Calculator CVSS V3.1 is available at <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>.
- Qualitative Exploitability Score Scale:
 - High when CVSS 3.1 Exploitability Score > 2
 - Moderate when CVSS 3.1 Exploitability Score range is [1-2]
 - Low when CVSS 3.1 Exploitability Score range is [<1]

⁵ Source: A detail explanation of these variables is available at <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>. This information is also provided in APPENDIX D of this document.

STEP 4B: Assess LIKELIHOOD of Threat Initiation from Adversarial threat agents/sources- This is a function of the *motivation score* of the adversarial threat agent/source (see **Table 7A**) and the *qualitative exploitability score* (see **Table 8**) of a vulnerability.

TABLE 9: Likelihood of Threat Initiation					
Asset ID	Vulnerability ID	Threat ID	Motivation Score for Threat Agent/Source	Ease of Exploitability Score	Likelihood of Threat Initiation Score
C	V1	T1	Low	High	Moderate
A		T2	Moderate	High	Moderate
D	V2	T3	High	Low	Moderate
I		T4	Low	Low	Very Low
D	V3	T5	High	High	High
F	V4	T6	Moderate	Moderate	Moderate
B	V5	T7	Moderate	High	Moderate
E	V6	T8	Moderate	Very High	High
I	V7	T9	High	High	High
	V8	T10	High	High	High
G	V9	T11	Moderate	High	Moderate
A	V10	T12	High	High	High
		T13	Moderate	High	Moderate
C	V11	T14	Low	Low	Very Low
A	V12	T15	Low	Low	Very Low
D	V15	T16	Moderate	Low	Low

TABLE 10: Look-Up table for estimating the Likelihood of Threat Initiation					
Ease of Exploitability	Motivation of the Threat Agent/Source				
	Very Low	Low	Moderate	High	Very High
Very High	Low	Moderate	High	Very High	Very High
High	Low	Moderate	Moderate	High	Very High
Moderate	Low	Low	Moderate	Moderate	High
Low	Very Low	Very Low	Low	Moderate	Moderate

STEP 4C: Assess the Likelihood of Adverse Impact- In this step we assess whether the successful exploitation of a vulnerability or set of vulnerabilities by threat agent(s)/source will adversely impact the organization's IT assets and business processes. Specific examples of adverse impact are provided in *APPENDIX E*.

TABLE 11: Assessment of the Likelihood of Adverse Impact from a Threat event				
Asset ID	Vulnerability ID	Threat ID	Adverse Impact Score*	Justification for the Adverse Impact Score
C	V1	T1	High	Unauthorized modification of financial records can lead to incorrect billing, fraudulent insurance claims, and reputational damage.
A		T2	Very High	Exploitation of the PDIS could cause data breaches affecting confidentiality, treatment errors, and legal liability under HIPAA.
D	V2	T3	Moderate	Exposure of employee data (e.g., salaries, credentials) could result in privacy violations but has limited operational disruption.
I		T4	High	Unsecured workstations may allow unauthorized access to multiple systems, risking patient data compromise and workflow disruption.
D	V3	T5	High	Unauthorized changes to personnel data could result in employment fraud, credential mismatches, or payroll errors.
F	V4	T6	Very High	Tampering with RxS could cause incorrect drug dispensing, risking patient safety and potential fatalities.
B	V5	T7	Very High	Failure of ECDS can delay emergency care, risking life-threatening consequences and massive liability.
E	V6	T8	High	Unauthorized vendor access can disrupt the supply chain, affecting treatment availability and procurement integrity.
I	V7	T9	High	Exploitable endpoint vulnerabilities can act as entry points to sensitive systems, potentially spreading malware.
	V8	T10	Moderate	Exploitation of generic endpoint services could allow lateral movement but might have an isolated impact depending on access level.
G	V9	T11	High	Compromised email server may leak sensitive patient or staff communication and serve as a phishing or malware vector.
A	V10	T12	Very High	Misuse of open sessions in PDIS can result in mass data compromise, medical errors, and lawsuits.
		T13	Very High	Combined threat of multiple vulnerabilities in PDIS makes it the most critical target for potential compromise.
C	V11	T14	High	Financial system manipulation could cause operational delays, false billing, and stakeholder distrust.
A	V12	T15	High	Remote access flaws can be exploited to hijack PDIS remotely, impacting both system integrity and patient safety.
D	V15	T16	Moderate	Unpatched HR systems may lead to data exposure, but impact on patient care is indirect.
NOTE: *Adverse Impact Score Scale: Very High=> If the threat event is initiated or occurs, it is almost certain to have adverse impacts. High=> If the threat event is initiated or occurs, it is highly likely to have adverse impacts. Moderate=> If the threat event is initiated or occurs, it is likely to have adverse impacts. Low=> If the threat event is initiated or occurs, it is unlikely to have adverse impacts. Very Low=> If the threat event is initiated or occurs, it is highly unlikely to have adverse impacts.				

STEP 4D: ASSESSMENT SCALE – OVERALL LIKELIHOOD

TABLE 12: Overall Likelihood of a Threat Event					
Asset ID	Vulnerability ID	Threat ID	Likelihood of Threat Event Initiation or Occurrence	Likelihood Threat Events Result in Adverse Impacts	Overall Likelihood of Threat Event
C	V1	T1	Moderate	High	Moderate
A		T2	Moderate	Very High	High
D	V2	T3	Moderate	Moderate	Moderate
I		T4	Very Low	High	Low
D	V3	T5	High	High	High
F	V4	T6	Moderate	Very High	High
B	V5	T7	Moderate	Very High	High
E	V6	T8	High	High	High
I	V7	T9	High	High	High
	V8	T10	High	Moderate	Moderate
G	V9	T11	Moderate	High	Moderate
A	V10	T12	High	Very High	Very High
		T13	Moderate	Very High	High
C	V11	T14	Very Low	High	Low
A	V12	T15	Very Low	High	Low
D	V15	T16	Low	Moderate	Low

TABLE 13: Look-Up table for estimating the Overall Likelihood of a Threat Event					
Likelihood of Threat Event Initiation or Occurrence	Likelihood Threat Events Result in Adverse Impacts				
	Very Low	Low	Moderate	High	Very High
Very High	Low	Moderate	High	Very High	Very High
High	Low	Moderate	Moderate	High	Very High
Moderate	Low	Low	Moderate	Moderate	High
Low	Very Low	Low	Low	Moderate	Moderate
Very Low	Very Low	Very Low	Low	Low	Low
NOTE: Explanation of the qualitative measures for the <i>Overall Likelihood of Threat</i> event happening. • Very High => Threat will happen • High => Threat event will most likely happen • Moderate => Threat is likely to happen • Low => Threat may happen • Very Low => Threat event is unlikely to happen					

Not all threats are equally likely. Estimating likelihood helps prioritize which threats require urgent mitigation. We broke this down into two parts:

- 4A: Motivation of the threat actor
- 4B: Ease of exploiting the vulnerability

What we did:

- Scored threat actor motivation using a formula based on capability, intent, and targeting.
- Used the CVSS v3.1 scoring model to assess how easy it would be to exploit each vulnerability (e.g., attack vector, privilege required).

Calculated motivation and exploitability scores, revealing that insider misuse and nation-state threats targeting legacy systems pose the highest likelihood of occurrence.

STEP 5: ESTIMATE IMPACT ON IT ASSETS, BUSINESS PROCESSES, AND ORGANIZATION

The level of *impact* from a threat event is the magnitude of harm that can be expected to result from the consequences of unauthorized disclosure of information, unauthorized modification of information, unauthorized destruction of information, or loss of information or information system availability. In this step, we estimate the impact of a threat on IT assets (Confidentiality, Integrity, and/or Availability of the asset), business processes (operational disruption), and the organization (financial impact).

TABLE 14: Measurement Scales for Impact After a Threat Event Happens	
<u>Assessment Scale for Impact on Confidentiality of the Targeted IT Asset</u>	
• High [10]- Confidentiality of the targeted IT asset is fully compromised after the threat event • Medium [5]- Confidentiality is partially compromised after the threat event • Low [1]- Confidentiality is not compromised after the threat event	
<u>Assessment Scale for Impact on Integrity of the Targeted IT Asset</u>	
• High [10]- Integrity of the targeted IT asset is fully compromised after the threat event • Medium [5]- Integrity of the targeted IT asset is partially compromised after the threat event • Low [1]- Integrity of the targeted IT asset is not compromised after the threat event	
<u>Assessment Scale for Impact on Availability of the Targeted IT Asset</u>	
• High [10]- Availability of the targeted IT asset is fully compromised after the threat event • Medium [5]- Availability of the targeted IT asset is partially compromised after the threat event • Low [1]- Availability of the targeted IT asset is not compromised after the threat event	
<u>Assessment Scale for Impact on Business Process</u>	
• Very High [10]- Asset failure will result in a total disruption of the business process for at least 2 hours • High [7]- Asset failure will result in slowing down of the business process • Moderate [4]- Asset failure will have minimal impact on the business process • Low [2]- Asset failure will have no impact on the business process • Very Low [0]- Almost no impact on the business process	
<u>Assessment Scale for Financial Impact on the Organization</u>	
• High [10] => Threat event will result in the cost of detection & escalation, incident notification, incident response, and lost business exceeding \$1 million • Medium [5] => Threat event will the cost of detection & escalation, incident notification, incident response, and lost business exceeding \$0.5 million but less than \$1 million	

- **Low [1]** => Threat event will the cost of detection & escalation, incident notification, incident response, and lost business exceeding of less than \$0.5 million

Assessment Scale for Legal impact on the Organization

- **High [10]** => Asset failure will result in legal action that could lead to imprisonment, fines exceeding \$1 million
- **Medium [5]** => Asset failure will result in legal action for correction and fines between \$0.5 - \$1 million
- **None [0]** => Asset failure will result in no legal action

	TABLE 15: Estimate the Final Impact Value (FIV) due to a Threat Event											
Asset ID	Vulnerability ID	Threat ID			Impact						Final Impact Value (FIV)	Final Impact Value (FIV)
			IT Asset			Business Process			Organization			
			C	I	A	BP1	BP2	BP3	Financial	Legal		
C	V1	T1	5	10	1	0	10	0	9	7	42	High
A		T2	10	10	10	10	0	0	10	10	60	High
D	V2	T3	5	5	1	0	0	7	5	0	23	Moderate
I		T4	5	5	5	7	4	0	5	0	31	Moderate
D	V3	T5	5	5	1	0	0	7	5	0	23	Moderate
F	V4	T6	5	10	10	10	0	0	10	10	55	High
B	V5	T7	5	10	10	10	0	0	10	10	55	High
E	V6	T8	1	5	5	7	4	0	5	0	27	Moderate
I	V7	T9	5	5	5	7	4	0	5	0	31	Moderate
	V8	T10	1	5	1	7	2	0	5	0	21	Moderate
G	V9	T11	10	10	5	10	0	0	10	5	50	High
A	V10	T12	10	10	10	10	0	0	10	10	60	High
		T13	10	10	10	10	0	0	10	10	60	High

C	V11	T14	5	1 0	1	0	10	0	10	10	46	High
A	V12	T15	5	1 0	5	10	0	0	10	5	45	High
D	V15	T16	5	5	1	0	0	7	5	0	23	Moderate
NOTES: • C => Confidentiality of the IT Asset • I => Integrity of the IT Asset • A => Availability of the IT Asset • Business Process (BP)- Specify here the business process that is impacted. This information will be from <i>TABLE 1</i> [in <i>STEP 1</i>]. If more than one business process is impacted by a vulnerability-threat pair, then for each business process, add a column to the table. In this table we are assuming two business processes only, i.e., BP1 and BP2. • Financial impact includes the sum of Detection and Escalation, Notification of Cyber-attack to Relevant Stakeholders, Incident Response, and Lost Business costs. • Legal impact could include fines, jail time, and reimbursing individuals and organizations affected by the threat. The relevant state and federal cybersecurity laws should be specified when defining the assessment scale for legal impact. • Final Impact Value (FIV) is a function of the impact on IT assets, operational, financial, and legal impact values. This could be as simple as a sum of the semi-qualitative values for these variables, or some other mathematical function. • * <i>FIV Qualitative Score</i> Scale: Very High=> When $60 < \text{FIV Semi-Qualitative Value} \leq 70$ High=> When $40 < \text{FIV Semi-Qualitative Value} \leq 60$ Moderate=> When $20 < \text{FIV Semi-Qualitative Value} \leq 40$ Low=> When $10 < \text{FIV Semi-Qualitative Value} \leq 20$ Very Low=> When $\text{FIV Semi-Qualitative Value} \leq 10$												

A highly likely threat that causes minimal harm may not be a priority — but a moderate threat that shuts down patient access to medication systems could be catastrophic. Impact tells us the “so what?” of each risk.

What we did:

- Evaluated impact based on confidentiality, integrity, and availability (CIA), along with operational disruption and legal exposure (e.g., HIPAA fines).
- Scored each risk scenario across business process tiers.

Identified top-impact scenarios such as unauthorized access to patient data (violating HIPAA), disruption of emergency care (via ECDS outage), and financial data manipulation.

STEP 6: ESTIMATE THE CYBERSECURITY RISK

Cybersecurity *risk* is a function of the likelihood of a threat event’s occurrence and potential adverse impact should the event occur. This definition accommodates several types of adverse impacts at all tiers in the risk management hierarchy described in Special Publication 800-39 (e.g., damage to image or reputation of the organization or financial loss at Tier 1; inability to successfully execute a specific mission/business process at Tier 2; or the resources expended in responding to an information system incident at Tier 3). It also accommodates relationships among impacts (e.g., loss of current or future mission/business effectiveness due to the loss of data confidentiality; loss of confidence in critical information due to loss of

data or system integrity; or unavailability or degradation of information or information systems). This broad definition also allows risk to be represented as a single value.

At Aggieland Medical Center, cybersecurity risk is evaluated as a function of two primary factors:

1. Likelihood of Threat Event Occurrence
2. Potential Adverse Impact if the Event Occurs

This assessment follows NIST SP 800-39 and aligns with AMC's tiered environment:

- Tier 1 (Organizational): Impacts to AMC's public trust, reputation, or legal standing (e.g., HIPAA violations).
- Tier 2 (Business Process): Disruptions to patient care, financial operations, or supply chains.
- Tier 3 (Information System): Outages, compromises, or misuse of IT systems such as PDIS, FRKS, or RxS.

The interplay of these impacts can compound risk. For instance:

- A loss of data confidentiality (e.g., patient records leaked via PDIS) could harm patient trust and trigger regulatory action.
- A loss of system integrity (e.g., financial records tampered via FRKS) could result in compliance breaches or billing errors.
- A loss of availability (e.g., RxS crash during peak hours) could delay patient care and medication delivery.

Risk is ultimately expressed on a qualitative risk matrix—cross-referencing likelihood (Steps 4A–4B) with impact scores—to guide prioritization and remediation.

TABLE 16: RISK MATRIX for Looking up the Level of Risk ⁶					
Likelihood that Threat Event Occurs and Results in Adverse Impact	FINAL IMPACT VALUE (FIV)				
	Very Low	Low	Moderate	High	Very High
Very High	Very Low	Moderate	High	High	Very High
High	Very Low	Low	Moderate	High	Very High
Moderate	Very Low	Low	Moderate	Moderate	High
Low	Very Low	Low	Low	Low	Moderate
Very Low	Very Low	Very Low	Very Low	Low	Low
NOTE: Explanation of the qualitative measures for levels of risk. • Very High => Very high risk means that a threat event could be expected to have multiple severe or catastrophic adverse effects on organizational operations, organizational assets, individuals, other organizations, or the Nation. • High => High risk means that a threat event could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation. • Moderate => Moderate risk means that a threat event could be expected to have a serious adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation. • Low => Low risk means that a threat event could be expected to have a limited adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation. • Very Low => Very low risk means that a threat event could be expected to have a negligible adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.					

⁶ The levels of risk are explained Appendix G.

TABLE 17: Cybersecurity Risk to IT Assets					
Asset ID	Vulnerability ID	Threat ID	Threat Event Likelihood	Final Impact Value (FIV)	Risk Level
C	V1	T1	Moderate	High	Moderate
A		T2	High	High	High
D	V2	T3	Moderate	Moderate	Moderate
I		T4	Low	Moderate	Low
D	V3	T5	High	Moderate	Moderate
F	V4	T6	High	High	High
B	V5	T7	High	High	High
E	V6	T8	High	Moderate	Moderate
I	V7	T9	High	Moderate	Moderate
	V8	T10	Moderate	Moderate	Moderate
G	V9	T11	Moderate	High	Moderate
A	V10	T12	Very High	High	High
		T13	High	High	High
C	V11	T14	Low	High	Low
A	V12	T15	Low	High	Low
D	V15	T16	Low	Moderate	Low

This step brings everything together: likelihood $\times$ impact = risk. The goal is to prioritize the most dangerous scenarios and provide a clear risk picture for AMC's leadership.

What we did:

- Combined likelihood and impact values in a risk matrix.
- Ranked risks from critical to low based on actual context, not just theoretical vulnerabilities.

Generated a ranked list of risks and a qualitative heatmap. Highest risks included:

- Excessive privilege misuse in PDIS
- Remote code execution threats via unpatched systems
- Insider threats due to poor session hygiene and account deprovisioning

SUMMARY of the PROCESS

This process consists of SIX STEPS.

STEP 1: Identify and document the relevant business processes (TABLE 1), and IT assets (TABLE 3).

STEP 2: Identify and document vulnerabilities (TABLE 4)

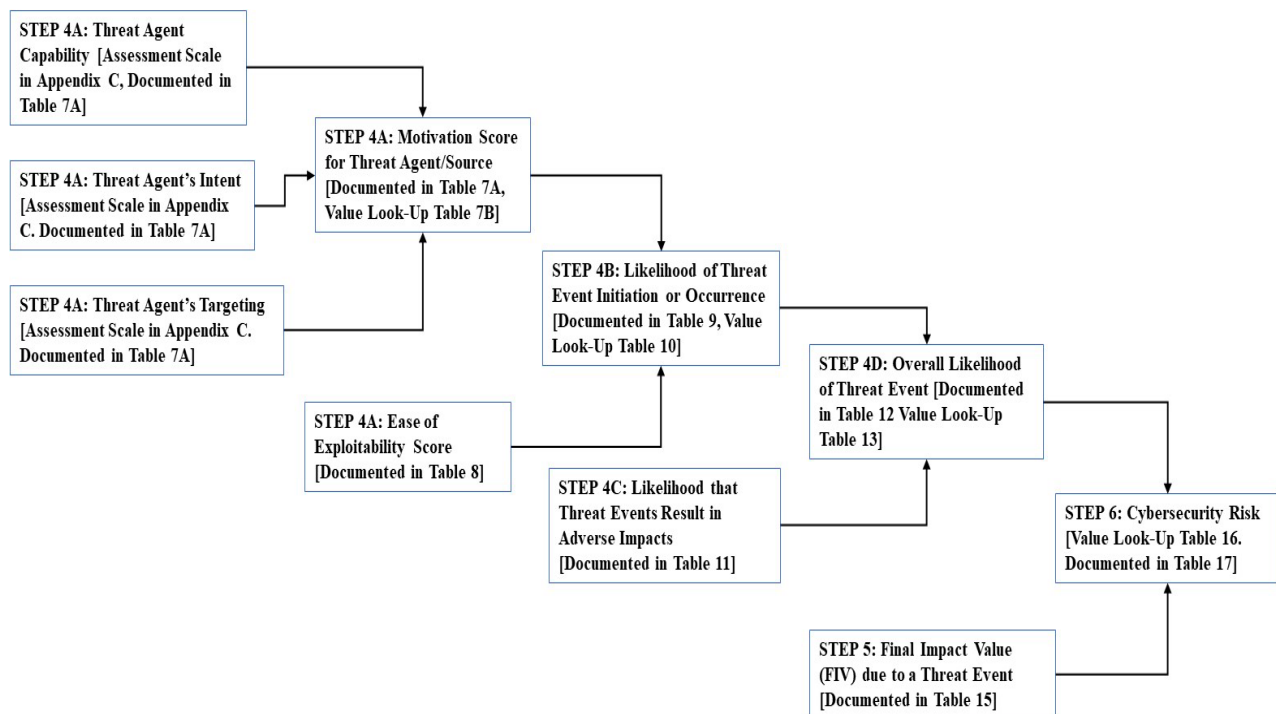
STEP 3: Identify the threats that are relevant to the vulnerabilities and document them (TABLE 6).

STEP 4: In this step- (a) Assess the threat agent's/source's motivation (TABLE 7A) and the ease with which the relevant vulnerability can be exploited (TABLE 8) and then use these two values to (b) determine the likelihood that the threat event is initiated by the threat agent/source (TABLE 9); and (c) score the likelihood that the threat event will result in an adverse impact (TABLE 11).

STEP 5: Determine the Final Impact Value of the threat event (TABLE 15)

STEP 6: Determine the cybersecurity risk due to a threat event (TABLE 17).

STEP 4-STEP 6 are illustrated in the following figure.



Conclusion

This cybersecurity risk assessment of **Aggieland Medical Center (AMC)** revealed a complex and evolving risk landscape shaped by legacy systems, decentralized access controls, vendor integration challenges, and a growing reliance on digital healthcare infrastructure. By applying the structured framework defined in **NIST SP 800-30 Revision 1** and adapting it specifically to AMC's clinical and operational environment, we identified and analyzed critical assets, vulnerabilities, credible threat events, and their associated likelihoods and impacts.

Key findings from this assessment include:

- **Excessive privilege inheritance** across systems such as PDIS and FRKS, significantly increasing the risk of insider threats.
- **Legacy software and hardware** (e.g., RedHat 6, unsupported email servers) that contain exploitable known vulnerabilities (CVEs), with confirmed relevance to AMC's environment.
- **Insufficient segmentation and oversight** for third-party vendors, especially those with access to MLS and RxS systems.
- **Administrative and procedural gaps**, including inconsistent deprovisioning, shared workstations, weak session controls, and lack of comprehensive staff training on security awareness.
- **Reconnaissance and delivery techniques** applicable to AMC's environment that adversaries could use to gain initial access or escalate privileges internally.

The **top risks** identified through this qualitative approach represent a threat to patient safety, regulatory compliance (e.g., HIPAA), financial integrity, and organizational trust. Risk drivers such as privilege escalation, remote code execution, and unmonitored insider activity were ranked as high or critical based on likelihood and potential operational impact.

Strategic Recommendations

To mitigate the most urgent risks and strengthen AMC's security posture, we recommend the following:

- **Enforce Role-Based Access Control (RBAC):** Eliminate inherited privileges and implement least-privilege principles with scheduled access reviews across all critical systems.
- **Modernize Legacy Infrastructure:** Prioritize decommissioning unsupported platforms such as RedHat 6 and outdated SQL Server instances, and replace them with modern, monitored, and patchable alternatives.
- **Establish Centralized Vendor Risk Governance:** Implement vendor onboarding protocols that include segmentation, access audits, and periodic compliance assessments to reduce exposure from third-party tools and service providers.
- **Implement Multi-Factor Authentication (MFA) and Session Timeout Policies:** Apply MFA to all remote access channels (e.g., VPN, RxS portals) and enforce automatic logout across all shared workstations.
- **Conduct Security Awareness Training Tailored to Clinical Contexts:** Deliver role-specific cybersecurity training with real-world examples from healthcare (e.g., phishing targeting physicians, ransomware in ERs) to promote behavioral change.
- **Develop and Test an Incident Response Plan:** Align AMC's IR procedures with HIPAA and industry best practices to ensure rapid, coordinated response to future cyber incidents, including ransomware or data breaches.
- **Introduce Real-Time Monitoring and Log Correlation:** Implement Security Information and Event Management (SIEM) tools to enable continuous monitoring of user activity, privilege escalations, and anomalous behavior across sys

APPENDIX A: Examples of *adversarial threat events* [Source: NIST Special Publication 800-30 Revision 1]

Threat Events (Characterized by TTPs ¹)	Description
<i>Perform reconnaissance and gather information</i>	
T1 – Unauthorized access to FRKS via unsecured workstation	Adversaries physically explore AMC's finance areas with minimal oversight, gaining access to FRKS terminals and observing financial record structures without needing credentials.
T8 – Remote vendor exploit via unmonitored MLS access	Threat actors monitor AMC's public-facing vendor login portals to detect poorly secured remote access pathways and identify high-value targets like the MLS.
T13 – SQL injection targeting public PDIS endpoints	Adversaries probe web-accessible PDIS fields for injectable parameters to enumerate database structures and gain access to sensitive patient data.
Perform perimeter network reconnaissance/scanning.	Adversaries use tools like Nmap, Shodan, or Nessus to scan AMC's internet-facing systems — such as patient portals, VPN gateways, or vendor access points — in order to identify open ports, outdated services (e.g., RedHat 6 Email Server), and unpatched vulnerabilities they can later exploit.
Perform network sniffing of exposed networks.	An attacker with physical or unauthorized wireless access (e.g., in a public waiting area or near unsecured admin offices) monitors traffic on AMC's internal or guest Wi-Fi to extract login credentials, EHR system usage patterns, or unencrypted communications between clinical devices and central servers.
Gather information using open-source discovery of organizational information.	Adversaries collect publicly available data from AMC's website, staff LinkedIn profiles, vendor documentation, or academic publications. This may include email formats, software platforms used (e.g., MS SQL Server), and names of system administrators — all used to craft targeted phishing or social engineering attacks.
Perform reconnaissance and surveillance of targeted organizations.	Attackers observe AMC's physical layout and workflow patterns to identify potential weaknesses — such as unattended workstations, staff ID badge behavior, or vendor access procedures. They may combine this with digital scanning to coordinate physical and cyber entry points.
Perform malware-directed internal reconnaissance	Once inside AMC's perimeter (e.g., via a phishing-delivered trojan), malware probes systems like FRKS or Rxs to locate sensitive data stores, high-privilege accounts, or lateral movement opportunities — all while evading externally positioned intrusion detection systems.
<i>Craft or create attack tools.</i>	
T9 – Windows kernel exploit on legacy workstations	Attacker prepares an exploit payload targeting unpatched Windows 7 vulnerabilities (e.g., CVE-2015-6131), potentially delivered via USB or local access to escalate privileges.
T11 – Sendmail buffer overflow compromise	Custom exploit kits are tailored to AMC's use of Sendmail 8.9.3 on Red Hat 6, allowing remote execution or denial-of-service attacks on the hospital's email server.
Craft phishing attacks.	Adversaries impersonate trusted entities (e.g., EHR system vendors, IT support, Medicare payers) via emails sent to AMC staff. These messages may prompt users to log in to a fake portal resembling PDIS or FRKS, harvesting credentials that can later be used for unauthorized access.
Craft spear phishing attacks.	Highly targeted phishing emails are sent to senior executives (e.g., CIO, CFO, Medical Director) or department heads using information gathered

	from AMC's public profiles or vendor contracts. The goal is often to gain access to privileged systems or initiate fraudulent transactions.
Craft attacks specifically based on deployed information technology environment.	Adversaries tailor malware or exploit payloads based on AMC's known tech stack (e.g., Sendmail 8.9.3, MS SQL Server, outdated RedHat OS). This allows attacks to bypass generic defenses and exploit system-specific vulnerabilities with high precision.
Create counterfeit/spoof website.	Attackers clone AMC's internal web portals (e.g., staff login page or vendor billing portal) and send links via phishing emails to lure users. Once users attempt to log in, their credentials are captured or malware is silently deployed to their systems.
Craft counterfeit certificates.	An adversary compromises a certificate authority or generates a spoofed SSL certificate for a counterfeit AMC domain, making malicious sites appear legitimate to staff or vendors accessing them from browsers or internal tools.
Create and operate false front organizations to inject malicious components into the supply chain.	Attackers pose as legitimate medical equipment vendors or software integrators to introduce backdoored systems or corrupted updates into AMC's Medical Logistics Server (MLS) or RxS supply chain — compromising inventory tracking or pharmaceutical integrity.
<i>Deliver/insert/install malicious capabilities.</i>	
T10 – RCE on Win10 via unpatched vulnerability	Remote attackers send crafted payloads (phishing attachments or exploit kits) targeting known RCE vulnerabilities in AMC's Windows 10 machines, enabling silent installation of malware.
T5 – Unauthorized access from stale HR credentials	A former employee (insider threat) retains active credentials and uses them to access and manipulate HR data via PMS. No revocation or monitoring processes detect this activity.
Deliver known malware to internal organizational information systems (e.g., virus via email).	Adversaries send phishing emails with attachments disguised as billing forms, HR documents, or vendor invoices. When opened by AMC staff, the malware (e.g., ransomware or info-stealers) installs on workstations with access to systems like FRKS or PMS.
Deliver modified malware to internal organizational information systems.	AMC users may be exposed to malware via compromised medical journal websites, vendor portals, or file-sharing tools. Malware is customized to evade signature-based antivirus solutions and may exploit browser or plug-in vulnerabilities.
Deliver targeted malware for control of internal systems and exfiltration of data.	Attackers deploy stealth malware within AMC's network to establish remote command-and-control. This malware identifies PHI from PDIS or RxS, exfiltrates it to external servers, and hides its activity from AMC's limited network monitoring systems.
Deliver malware by providing removable media.	Attackers strategically drop malware-infected USB drives in or near AMC facilities (e.g., parking lots, conferences). A curious staff member might plug the device into a workstation, allowing the malware to bypass perimeter defenses.
Insert untargeted malware into downloadable software and/or into	AMC staff download mobile apps or drivers from unofficial sources — for example, when managing device firmware updates — unknowingly

commercial information technology products.	introducing trojans that exploit default admin credentials or outdated antivirus protection.
Insert targeted malware into organizational information systems and information system components.	Adversaries tamper with software patches or hardware updates specifically configured for AMC's environment — such as custom MLS vendor tools or pharmacy automation systems — delivering malware that's pre-tailored to system architecture.
Insert specialized malware into organizational information systems based on system configurations.	Based on reconnaissance, attackers build custom malware for AMC's specific configurations — e.g., an exploit targeting Sendmail 8.9.3 or legacy SQL Server versions — that can remain undetected by generic security tools.
Insert counterfeit or tampered hardware into the supply chain.	Compromised third-party vendors deliver altered biometric devices, routers, or thin clients to AMC. These devices contain hidden backdoors or remote access functionality that allow persistent attacker access post-installation.
Insert tampered critical components into organizational systems.	Attackers replace trusted components (e.g., firmware chips or medical IoT sensors) with corrupted versions via vendor compromise or insider collusion. These components could exfiltrate data or serve as permanent intrusion vectors.
Install general-purpose sniffers on organization-controlled information systems or networks.	Malware installed on AMC systems (via phishing or USB) includes packet sniffers that log usernames, passwords, or internal server IPs — particularly dangerous in areas with flat network segmentation.
Install persistent and targeted sniffers on organizational information systems and networks.	Attackers deploy stealth sniffing tools to monitor traffic between critical systems like PDIS and ECDS. These tools are designed to evade detection and remain active long-term for patient data harvesting or login replay attacks.
Insert malicious scanning devices (e.g., wireless sniffers) inside facilities.	Adversaries mail or deliver concealed sniffing devices (e.g., rogue Raspberry Pi) to AMC's receiving/mailroom areas. Once active, these devices passively collect Wi-Fi traffic, credentials, or scan for misconfigured wireless printers.
Insert subverted individuals into organizations.	The adversary recruits or manipulates contractors or temporary employees (e.g., janitorial staff or external IT support) with physical access to drop malware, gather printed PHI, or plug devices into active workstations.
Insert subverted individuals into privileged positions in organizations.	Threat actors target privileged roles (e.g., system administrators, pharmacy tech leads) through fake recruiting, bribery, or social engineering, with the goal of gaining access to sensitive systems or administrative tools. These insiders can alter records, disable logging, or exfiltrate credentials.
<i>Exploit and compromise</i>	
T2 – Exploitation of excessive privileges in PDIS	Insider or attacker uses inherited roles in PDIS to perform unauthorized database queries, alter patient records, or disable audit logging features.

T4 – Patient data exposed via unattended PDIS screens	Walk-in attackers or patients view or interact with unattended PDIS sessions left open in treatment rooms. No screen locking or timeout policies are enforced.
T6 – RxS tampering due to weak authentication	Adversary logs into RxS using shared or weak credentials, altering drug prescriptions and creating potential for medical fraud or physical harm.
T12 – SQL Server privilege escalation in PDIS	Exploiting unpatched SQL Server on PDIS allows attackers to elevate access to admin privileges and execute commands directly on the database.
Exploit physical access of authorized staff to gain access to organizational facilities.	Adversary follows (“tailgates”) authorized individuals into secure/controlled locations with the goal of gaining access to facilities, circumventing physical security checks.
Exploit poorly configured or unauthorized information systems exposed to the Internet.	Adversary gains access through the Internet to information systems that are not authorized for Internet connectivity or that do not meet organizational configuration requirements.
Exploit split tunneling.	Adversary takes advantage of external organizational or personal information systems (e.g., laptop computers at remote locations) that are simultaneously connected securely to organizational information systems or networks and to nonsecure remote connections.
Exploit multi-tenancy in a cloud environment.	Adversary, with processes running in an organizationally used cloud environment, takes advantage of multi-tenancy to observe behavior of organizational processes, acquire organizational information, or interfere with the timely or correct functioning of organizational processes.
Exploit known vulnerabilities in mobile systems (e.g., laptops, PDAs, smart phones).	Adversary takes advantage of fact that transportable information systems are outside physical protection of organizations and logical protection of corporate firewalls, and compromises the systems based on known vulnerabilities to gather information from those systems.
Exploit recently discovered vulnerabilities.	Adversary exploits recently discovered vulnerabilities in organizational information systems to compromise the systems before mitigation measures are available or in place.
Exploit vulnerabilities on internal organizational information systems.	Adversary searches for known vulnerabilities in organizational internal information systems and exploits those vulnerabilities.
Exploit vulnerabilities using zero-day attacks.	Adversary employs attacks that exploit as yet unpublicized vulnerabilities. Zero-day attacks are based on adversary insight into the information systems and applications used by organizations as well as adversary reconnaissance of organizations.
Exploit vulnerabilities in information systems timed with organizational mission/business operations tempo.	Adversary launches attacks on organizations in a time and manner consistent with organizational needs to conduct mission/business operations.
Exploit insecure or incomplete data deletion in multi-tenant environment.	Adversary obtains unauthorized information due to insecure or incomplete data deletion in a multi-tenant environment (e.g., in a cloud computing environment).

Violate isolation in multi-tenant environment.	Adversary circumvents or defeats isolation mechanisms in a multi-tenant environment (e.g., in a cloud computing environment) to observe, corrupt, or deny service to hosted services and information/data.
Compromise critical information systems via physical access.	Adversary obtains physical access to organizational information systems and makes modifications.
Compromise information systems or devices used externally and reintroduced into the enterprise.	Adversary installs malware on information systems or devices while the systems/devices are external to organizations for purposes of subsequently infecting organizations when reconnected.
Compromise software of organizational critical information systems.	Adversary inserts malware or otherwise corrupts critical internal organizational information systems.
Compromise organizational information systems to facilitate exfiltration of data/information.	Adversary implants malware into internal organizational information systems, where the malware over time can identify and then exfiltrate valuable information.
Compromise mission-critical information.	Adversary compromises the integrity of mission-critical information, thus preventing or impeding the ability of organizations to which information is supplied, from conducting operations.
Compromise design, manufacture, and/or distribution of information system components (including hardware, software, and firmware).	Adversary compromises the design, manufacture, and/or distribution of critical information system components at selected suppliers.
<i>Conduct an attack (i.e., direct/coordinate attack tools or activities)</i>	
T7 – Insider abuse undetected in ECDS due to lack of monitoring	An insider alters emergency care entries, routing decisions, or timestamps in ECDS without being logged or audited. Actions remain unnoticed due to absence of centralized logging or SIEM.
T14 – Financial record exposure due to open access	An attacker tampers with billing data or insurance claims by exploiting unmonitored physical access to FRKS workstations. Attack is deliberate and goal-driven.
T3 – Data compromise from shared HR workstations	Social engineers or untrained employees observe or modify personnel data in open shared PMS workstations due to lack of screen privacy or access isolation.
Conduct communications interception attacks.	Adversary takes advantage of communications that are either unencrypted or use weak encryption (e.g., encryption containing publicly known flaws), targets those communications, and gains access to transmitted information and channels.
Conduct wireless jamming attacks.	Adversary takes measures to interfere with wireless communications to impede or prevent communications from reaching intended recipients.
Conduct attacks using unauthorized ports, protocols, and services.	Adversary conducts attacks using ports, protocols, and services for ingress and egress that are not authorized for use by organizations.
Conduct attacks leveraging traffic/data movement allowed across perimeter.	Adversary makes use of permitted information flows (e.g., email communication, removable storage) to compromise internal information

	systems, which allows adversary to obtain and exfiltrate sensitive information through perimeters.
Conduct simple Denial of Service (DoS) attack.	Adversary attempts to make an Internet-accessible resource unavailable to intended users or prevent the resource from functioning efficiently or at all, temporarily or indefinitely.
Conduct Distributed Denial of Service (DDoS) attacks.	Adversary uses multiple compromised information systems to attack a single target, thereby causing denial of service for users of the targeted information systems.
Conduct targeted Denial of Service (DoS) attacks.	Adversary targets DoS attacks to critical information systems, components, or supporting infrastructures, based on adversary knowledge of dependencies.
Conduct physical attacks on organizational facilities.	Adversary conducts a physical attack on organizational facilities (e.g., sets a fire).
Conduct physical attacks on infrastructures supporting organizational facilities.	Adversary conducts a physical attack on one or more infrastructures supporting organizational facilities (e.g., breaks a water main, cuts a power line).
Conduct cyber-physical attacks on organizational facilities.	Adversary conducts a cyber-physical attack on organizational facilities (e.g., remotely changes HVAC settings).
Conduct data scavenging attacks in a cloud environment.	Adversary obtains data used and then deleted by organizational processes running in a cloud environment.
Conduct brute force login attempts/password guessing attacks.	Adversary attempts to gain access to organizational information systems by random or systematic guessing of passwords, supported by password cracking utilities.
Conduct nontargeted zero-day attacks.	Adversary employs attacks that exploit as yet unpublicized vulnerabilities. Attacks are not based on any adversary insights into specific vulnerabilities of organizations.
Conduct externally based session hijacking.	Adversary takes control of (hijacks) already established, legitimate information system sessions between organizations and external entities (e.g., users connecting from off-site locations).
Conduct internally-based session hijacking.	Adversary places an entity within organizations to gain access to organizational information systems or networks for the express purpose of taking control (hijacking) an already established, legitimate session either between organizations and external entities (e.g., users connecting from remote locations) or between two locations within internal networks.
Conduct externally-based network traffic modification (man in the middle) attacks.	Adversary, operating outside organizational systems, intercepts/eavesdrops on sessions between organizational and external systems. Adversary then relays messages between organizational and external systems, making them believe that they are talking directly to each other over a private connection, when in fact the adversary controls the entire communication. Such attacks are of particular concern for organizational use of community, hybrid, and public clouds.

Conduct internally-based network traffic modification (man in the middle) attacks.	Adversary operating within the organizational infrastructure intercepts and corrupts data sessions.
Conduct outsider-based social engineering to obtain information.	Externally placed adversary takes actions (e.g., using email, phone) with the intent of persuading or otherwise tricking individuals within organizations into revealing critical/sensitive information (e.g., personally identifiable information).
Conduct insider-based social engineering to obtain information.	Internally placed adversary takes actions (e.g., using email, phone) so that individuals within organizations reveal critical/sensitive information (e.g., mission information).
Conduct attacks targeting and compromising personal devices of critical employees.	Adversary targets key organizational employees by placing malware on their personally owned information systems and devices (e.g., laptop/notebook computers, personal digital assistants, smart phones). The intent is to take advantage of any instances where employees use personal information systems or devices to manage critical/sensitive information.
Conduct supply chain attacks targeting and exploiting critical hardware, software, or firmware.	Adversary targets and compromises the operation of software (e.g., through malware injections), firmware, and hardware that performs critical functions for organizations. This is accomplished as supply chain attacks on both commercial off-the-shelf and custom information systems and components.
<i>Achieve results (i.e., cause adverse impacts, obtain information)</i>	
Obtain sensitive information through network sniffing of external networks.	Adversary with access to exposed wired or wireless data channels that organizations (or organizational personnel) use to transmit information (e.g., kiosks, public wireless networks) intercepts communications.
Obtain sensitive information via exfiltration.	Adversary directs malware on organizational systems to locate and surreptitiously transmit sensitive information.
Cause degradation or denial of attacker-selected services or capabilities.	Adversary directs malware on organizational systems to impair the correct and timely support of organizational mission/business functions.
Cause deterioration/destruction of critical information system components and functions.	Adversary destroys or causes deterioration of critical information system components to impede or eliminate organizational ability to conduct missions or business functions. Detection of this action is not a concern.
Cause integrity loss by creating, deleting, and/or modifying data on publicly accessible information systems (e.g., web defacement).	Adversary vandalizes, or otherwise makes unauthorized changes to, organizational websites or data on websites.
Cause integrity loss by polluting or corrupting critical data.	Adversary implants corrupted and incorrect data in critical data, resulting in suboptimal actions or loss of confidence in organizational data/services.

Cause integrity loss by injecting false but believable data into organizational information systems.	Adversary injects false but believable data into organizational information systems, resulting in suboptimal actions or loss of confidence in organizational data/services.
Cause disclosure of critical and/or sensitive information by authorized users.	Adversary induces (e.g., via social engineering) authorized users to inadvertently expose, disclose, or mishandle critical/sensitive information.
Cause unauthorized disclosure and/or unavailability by spilling sensitive information.	Adversary contaminates organizational information systems (including devices and networks) by causing them to manage information of a classification/sensitivity for which they have not been authorized. The information is exposed to individuals who are not authorized access to such information, and the information system, device, or network is unavailable while the spill is investigated and mitigated.
Obtain information by externally located interception of wireless network traffic.	Adversary intercepts organizational communications over wireless networks. Examples include targeting public wireless access or hotel networking connections, and drive-by subversion of home or organizational wireless routers.
Obtain unauthorized access.	Adversary with authorized access to organizational information systems, gains access to resources that exceeds authorization.
Obtain sensitive data/information from publicly accessible information systems.	Adversary scans or mines information on publicly accessible servers and web pages of organizations with the intent of finding sensitive information.
Obtain information by opportunistically stealing or scavenging information systems/components.	Adversary steals information systems or components (e. g., laptop computers or data storage media) that are left unattended outside of the physical perimeters of organizations or scavenges discarded components.
<i>Maintain a presence or set of capabilities</i>	
T15 – Hijacking PDIS via unattended sessions	Unauthorized actors maintain persistent access to PDIS by reusing unlocked terminal sessions, bypassing the need for authentication. No session timeout policies are in place.
Obfuscate adversary actions.	Adversary takes actions to inhibit the effectiveness of the intrusion detection systems or auditing capabilities within organizations.
Adapt cyber-attacks based on detailed surveillance.	Adversary adapts behavior in response to surveillance and organizational security measures.
<i>Coordinate a campaign</i>	
T16 – Data leak via shared cramped HR terminals	Attackers or malicious insiders plan repeated access to shared terminals in cramped office spaces to exfiltrate HR data gradually, using low-and-slow techniques that evade detection.
Coordinate a campaign of multi-staged attacks (e.g., hopping).	Adversary moves the source of malicious commands or actions from one compromised information system to another, making analysis difficult.
Coordinate a campaign that combines internal and external attacks across	Adversary combines attacks that require both physical presence within organizational facilities and cyber methods to achieve success. Physical

multiple information systems and information technologies.	attack steps may be as simple as convincing maintenance personnel to leave doors or cabinets open.
Coordinate campaigns across multiple organizations to acquire specific information or achieve desired outcome.	Adversary does not limit planning to the targeting of one organization. Adversary observes multiple organizations to acquire necessary information on targets of interest.
Coordinate a campaign that spreads attacks across organizational systems from existing presence.	Adversary uses existing presence within organizational systems to extend the adversary's span of control to other organizational systems including organizational infrastructure. Adversary thus is in position to further undermine organizational ability to conduct missions/business functions.
Coordinate a campaign of continuous, adaptive, and changing cyber-attacks based on detailed surveillance.	Adversary attacks continually change in response to surveillance and organizational security measures.
Coordinate cyber-attacks using external (outsider), internal (insider), and supply chain (supplier) attack vectors.	Adversary employs continuous, coordinated attacks, potentially using all three attack vectors for the purpose of impeding organizational operations.

APPENDIX B: Examples of *non-adversarial threat events* [Source: NIST Special Publication 800-30 Revision 1].

REPRESENTATIVE EXAMPLES – NON-ADVERSARIAL THREAT EVENTS		
Threat Event (ID)	Category	Description (AMC-Specific)
N1 – Power outage affecting data center operations	Environmental	A localized power failure or power grid instability affects AMC's server room, causing downtime in critical systems like PDIS, ECDS, and FRKS due to lack of UPS/backup redundancy.
N2 – Network failure due to firewall misconfiguration or overload	Technical (Accidental)	A misconfiguration in the Cisco ASA firewall or system overload results in intermittent or total loss of connectivity, as reported in multiple departments using PDIS.
N3 – Data loss due to absence of automatic backups	Technical (Operational)	Systems like PDIS and ECDS are not backed up regularly, or backups are manually triggered, increasing the risk of permanent data loss during system crashes or cyber incidents.
N4 – Delayed system recovery due to insufficient IT staffing	Organizational	AMC's internal IT team lacks the headcount or skill level to respond to major incidents promptly, especially when ABC Systems (vendor) cannot be onsite quickly.
N5 – Accidental data exposure due to poor workstation practices	Human Error	Staff unintentionally expose sensitive data (e.g., leaving open records on unlocked screens) due to lack of awareness, tight office layout, or rushed workflows.
N6 – Failure to identify system intrusion due to lack of centralized monitoring	Technical (Operational)	AMC does not use a centralized logging or monitoring system (e.g., SIEM), leading to missed detection of anomalous behavior or signs of compromise in ECDS and SQL Server.
N7 – Environmental threat from server room flooding	Environmental	The server room is located in a flood-prone area of the hospital. In the event of plumbing failure or local weather disaster, all hosted systems could become inaccessible.
N8 – Staff inability to access systems due to authentication server failure	Technical	Authentication servers for systems like PDIS and PMS are not resilient. If the system fails or reboots unexpectedly, staff cannot log in, halting operations across departments.
N9 – Loss of patient trust due to publicized security incidents	Organizational / Reputational	Even in the absence of data breaches, frequent system outages, or minor exposure incidents (e.g., screen sharing), can lead to a loss of trust among patients or insurers.

APPENDIX C: Assessment of Threat Agent/Source Capability, Intent, and Targeting

[Source: NIST Special Publication 800-30 Revision 1].

Qualitative Value	Semi-Quantitative Range	Score	Description
Very High	96–100	10	The adversary has a highly sophisticated level of expertise, is well-resourced (e.g., nation-state or criminal syndicate), and can launch continuous, coordinated cyberattacks. This includes capabilities to penetrate healthcare systems, bypass perimeter defenses, exploit legacy infrastructure, and exfiltrate protected health information (PHI) at scale.
High	80–95	8	The adversary has advanced technical skills, access to automated exploit tools or malware kits, and the ability to conduct multi-stage attacks targeting medical devices, patient databases, or vendor-integrated platforms.
Moderate	21–79	5	The adversary has moderate capabilities and resources, such as the use of open-source attack scripts or phishing campaigns. They may exploit weak passwords, unpatched systems, or poorly segmented networks in healthcare facilities like AMC.
Low	5–20	2	The adversary has limited technical knowledge or tools, and may rely on social engineering, credential stuffing, or scanning for publicly known vulnerabilities in AMC's exposed systems.
Very Low	0–4	0	The adversary lacks the expertise or resources to successfully exploit AMC's information systems or carry out meaningful attacks. Their actions are unlikely to impact core clinical or administrative operations.

ASSESSMENT SCALE – CHARACTERISTICS OF ADVERSARY CAPABILITY

Qualitative Value	Semi-Quantitative Range	Score	Description
Very High	96–100	10	The adversary intends to seriously disrupt AMC's ability to deliver patient care, compromise large volumes of sensitive medical data, or disable critical systems (e.g., ECDS or PDIS). They may seek to inflict reputational, legal, or regulatory harm and are willing to risk detection to meet those objectives.
High	80–95	8	The adversary aims to gain or maintain unauthorized access to AMC's network in order to steal PHI, disrupt operations, or remain undetected for future campaigns. Their intent may include ransomware deployment or unauthorized billing manipulation.
Moderate	21–79	5	The adversary is motivated to access or tamper with AMC's systems or data (e.g., financial records or staff credentials), but may be more opportunistic. Their goal could be personal gain, low-scale fraud, or short-term disruption without advanced persistence.
Low	5–20	2	The adversary may act opportunistically without a targeted strategy — e.g., scanning for known vulnerabilities or exploiting poor user behavior — but without specific intent to harm AMC directly.
Very Low	0–4	0	The adversary lacks clear motivation or direction. Any activity is likely to be accidental, misdirected, or without a meaningful objective impacting AMC's operations or patient services.

ASSESSMENT SCALE – CHARACTERISTICS OF ADVERSARY INTENT

Qualitative Value	Semi-Quantitative Range	Score	Description
Very High	96–100	10	The adversary conducts targeted reconnaissance and persistent attacks against AMC's high-value systems (e.g., PDIS, FRKS), executives, or care providers. Their focus includes sensitive health data, billing infrastructure, or medical device integration points. They may also seek access via vendors or partner networks.
High	80–95	8	The adversary targets specific AMC services or personnel (e.g., billing staff, pharmacy managers, or IT admins) through phishing, malware, or credential theft. Their objective may include maintaining access to launch future attacks or manipulating transactions.
Moderate	21–79	5	The adversary targets healthcare institutions like AMC based on sector-wide vulnerabilities. They may use broad tactics (e.g., email phishing or generic exploits) and focus on typical high-risk roles such as HR, finance, or pharmacy operations.
Low	5–20	2	The adversary targets healthcare institutions like AMC based on sector-wide vulnerabilities. They may use broad tactics (e.g., email phishing or generic exploits) and focus on typical high-risk roles such as HR, finance, or pharmacy operations.
Very Low	0–4	0	The adversary does not actively seek to target AMC or similar institutions. Any exposure would be incidental or the result of automated attack tools probing the internet.

ASSESSMENT SCALE – CHARACTERISTICS OF ADVERSARY TARGETING

APPENDIX D: Vulnerability Attributes Used to Assess the Likelihood of a Threat Happening

Vulnerabilities are assessed in terms of *attack vector*, *attack complexity*, *privileges* required by the threat agent/source to exploit the vulnerability, *user interaction*, and the *scope* of the attack. These attributes borrowed from CVSS Exploitability Score calculator (<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>).

Attack Vector (AV)- This metric reflects the context by which vulnerability exploitation is possible. This metric value (and consequently the Base Score) will be larger the more remote (logically, and physically) an attacker can be to exploit the vulnerable component. The assumption is that the number of potential attackers for a vulnerability that could be exploited from across a network is larger than the number of potential attackers that could exploit a vulnerability requiring physical access to a device, and therefore warrants a greater Base Score. The list of values is presented in Table 1.

Table 1: Attack Vector

Metric Value **Description**

Network (N)	The vulnerable component is bound to the network stack and the set of possible attackers extends beyond the other options listed below, up to and including the entire Internet. Such a vulnerability is often termed “remotely exploitable” and can be thought of as an attack being exploitable <i>at the protocol level</i> one or more network hops away (e.g., across one or more routers). An example of a network attack is an attacker causing a denial of service (DoS) by sending a specially crafted TCP packet across a wide area network (e.g., CVE-2004-0230).
Adjacent (A)	The vulnerable component is bound to the network stack, but the attack is limited <i>at the protocol level</i> to a logically adjacent topology. This can mean an attack must be launched from the same shared physical (e.g., Bluetooth or IEEE 802.11) or logical (e.g., local IP subnet) network, or from within a secure or otherwise limited administrative domain (e.g., MPLS, secure VPN to an administrative network zone). One example of an Adjacent attack would be an ARP (IPv4) or neighbor discovery (IPv6) flood leading to a denial of service on the local LAN segment (e.g., CVE-2013-6014).
Local (L)	The vulnerable component is not bound to the network stack and the attacker's path is via read/write/execute capabilities. Either: - the attacker exploits the vulnerability by accessing the target system locally (e.g., keyboard, console), or remotely (e.g., SSH); <i>or</i> - the attacker relies on User Interaction by another person to perform actions required to exploit the vulnerability (e.g., using social engineering techniques to trick a legitimate user into opening a malicious document).
Physical (P)	The attack requires the attacker to physically touch or manipulate the vulnerable component. Physical interaction may be brief (e.g., evil maid attack ^[1]) or persistent. An example of such an attack is a cold boot attack in which an attacker gains access to disk encryption keys after physically accessing the target system. Other examples include peripheral attacks via FireWire/USB Direct Memory Access (DMA).

Scoring Guidance: When deciding between Network and Adjacent, if an attack can be launched over a wide area network or from outside the logically adjacent administrative network domain, use Network. Network should be used even if the attacker is required to be on the same intranet to exploit the vulnerable system (e.g., the attacker can only exploit the vulnerability from inside a corporate network).

Attack Complexity (AC)- This metric describes the conditions beyond the attacker’s control that must exist to exploit the vulnerability. As described below, such conditions may require the collection of more information about the target, or computational exceptions. Importantly, the assessment of this metric excludes any requirements for user interaction to exploit the vulnerability (such conditions are captured in the User Interaction metric). If a specific configuration is required for an attack to succeed, the Base metrics should be scored assuming the vulnerable component is in that configuration. The Base Score is greatest for the least complex attacks. The list of values is presented in Table 2.

Table 2: Attack Complexity

Metric Description
Value

Low (L)	Specialized access conditions or extenuating circumstances do not exist. An attacker can expect repeatable success when attacking the vulnerable component.
High (H)	A successful attack depends on conditions beyond the attacker's control. That is, a successful attack cannot be accomplished at will, but requires the attacker to invest in some measurable amount of effort in preparation or execution against the vulnerable component before a successful attack can be expected.[^2] For example, a successful attack may depend on an attacker overcoming any of the following conditions: ■ The attacker must gather knowledge about the environment in which the vulnerable target/component exists. For example, a requirement to collect details on target configuration settings, sequence numbers, or shared secrets. ■ The attacker must prepare the target environment to improve exploit reliability. For example, repeated exploitation to win a race condition, or overcoming advanced exploit mitigation techniques. ■ The attacker must inject themselves into the logical network path between the target and the resource requested by the victim in order to read and/or modify network communications (e.g., a man in the middle attack).

Privileges Required (PR)- This metric describes the level of privileges an attacker must possess *before* successfully exploiting the vulnerability. The Base Score is greatest if no privileges are required. The list of values is presented in Table 3.

Table 3: Privileges Required

Metric Description
Value

None (N)	The attacker is unauthorized prior to attack, and therefore does not require any access to settings or files of the vulnerable system to carry out an attack.
Low (L)	The attacker requires privileges that provide basic user capabilities that could normally affect only settings and files owned by a user. Alternatively, an attacker with Low privileges has the ability to access only non-sensitive resources.
High (H)	The attacker requires privileges that provide significant (e.g., administrative) control over the vulnerable component allowing access to component-wide settings and files.

Scoring Guidance: Privileges Required is usually None for hard-coded credential vulnerabilities or vulnerabilities requiring social engineering (e.g., reflected cross-site scripting, cross-site request forgery, or file parsing vulnerability in a PDF reader).

User Interaction (UI)- This metric captures the requirement for a human user, other than the attacker, to participate in the successful compromise of the vulnerable component. This metric determines whether the vulnerability can be exploited solely at the will of the attacker, or whether a separate user (or user-initiated process) must participate in some manner. The Base Score is greatest when no user interaction is required. The list of values is presented in Table 4.

Table 4: User Interaction

Metric Value	Description
--------------	-------------

None (N)	The vulnerable system can be exploited without interaction from any user.
Required (R)	Successful exploitation of this vulnerability requires a user to take some action before the vulnerability can be exploited. For example, a successful exploit may only be possible during the installation of an application by a system administrator.

Scope (S)- The Scope metric captures whether a vulnerability in one vulnerable component impacts resources in components beyond its *security scope*. Formally, a *security authority* is a mechanism (e.g., an application, an operating system, firmware, a sandbox environment) that defines and enforces access control in terms of how certain subjects/actors (e.g., human users, processes) can access certain restricted objects/resources (e.g., files, CPU, memory) in a controlled manner. All the subjects and objects under the authority of a single *security authority* are under one *security scope*. If a vulnerability in a vulnerable component can affect a component which is in a different *security scope* than the vulnerable component, a Scope change occurs. Intuitively, whenever the impact of a vulnerability breaches a security/trust boundary and impacts components outside the security scope in which vulnerable component resides, a Scope change occurs. The security scope of a component encompasses other components that provide functionality solely to that component, even if these other components have their own security authority. For example, a database used solely by one application is considered part of that application's security scope even if the database has its own security authority, e.g., a mechanism controlling access to database records based on database users and associated database privileges. The Base Score is greatest when a scope change occurs. The list of values is presented in Table 5.

Table 5: Scope

Metric Value	Description
--------------	-------------

Unchanged (U)	An exploited vulnerability can only affect resources managed by the same security authority. In this case, the vulnerable component and the impacted component are either the same, or both are managed by the same security authority.
Changed (C)	An exploited vulnerability can affect resources beyond the security scope managed by the security authority of the vulnerable component. In this case, the vulnerable component and the impacted component are different and managed by different security authorities.

APPENDIX E: EXAMPLES OF ADVERSE IMPACTS [Source: NIST Special Publication 800-30 Revision 1]

Type of Impact	Impact
HARM TO OPERATIONS	to deliver time-sensitive patient care (e.g., emergency treatment delays due to ECDS). ion in routine hospital workflows such as admissions, billing, or prescriptions. ate or delayed clinical decisions due to unavailable or corrupted medical records. to comply with federal healthcare regulations (e.g., HIPAA, HITECH), resulting in investigations. al loss due to ransomware, fraud, or rework from incorrect billing. own in trust with patients, physicians, or staff due to visible system failures or data e. ional damage in the local healthcare community and among partner institutions.

HARM TO ASSETS	corruption of Electronic Health Records (EHR) stored in PDIS. to pharmacy dispensing systems (RxS), financial systems (FRKS), or medical systems (MLS). availability of hospital equipment dependent on connected systems (e.g., diagnostics, imaging). physical damage or theft of medical devices, mobile workstations, or vendor-owned infrastructure. unauthorized access to sensitive configurations, staff credentials, or supply chain
HARM TO INDIVIDUALS	physical harm or delayed treatment resulting from system outages (e.g., downtime of ECDS for emergency care). exposure of sensitive patient data such as medical histories, lab results, or psychiatric information. psychological stress or fear among patients knowing their personal health information was compromised. financial theft due to PII exposure (e.g., Social Security Numbers, insurance details). damage to the personal or professional reputation of staff or physicians wrongly implicated in incidents.
HARM TO OTHER ORGANIZATIONS	regulatory violations affecting partner clinics, insurance providers, or state health exchanges due to data handling errors. financial penalties or lawsuits from breached Business Associate Agreements (BAAs). reputational harm to third-party vendors or payers integrated into AMC's systems (e.g., RxS, imaging vendors). loss of trust from vendors, partner hospitals, or affiliated universities in future collaborations. negative media attention that reduces AMC's attractiveness for grants, research partnerships, and recruitment.

ⁱ Tactics, Techniques, and Procedures